Research Square

Preprints are preliminary reports that have not undergone peer review.
They should not be considered conclusive, used to inform clinical practice,
or referenced by the media as validated information.

Enterprise Generative AI: A Systematic Review of Security Risks and Governance

Audrey Rah

arahimi@uh.edu

University of Houston https://orcid.org/0000-0001-7501-7809

Systematic Review

Keywords: AI Governance, Agentic AI, Composite Adoption Score, Enterprise Risk, Generative AI, NIST AI RMF, OWASP LLM Top 10, RAG Poisoning, Systematic Literature Review

Posted Date: June 3rd, 2026

DOI: https://doi.org/10.21203/rs.3.rs-9890887/v1

License: This work is licensed under a Creative Commons Attribution 4.0 International License.
Read Full License

Additional Declarations: The authors declare no competing interests.

Enterprise Generative AI: A Systematic Review of Security Risks and Governance

Audrey Rah
Department of Electrical and Computer Engineering
University of Houston
Houston, TX 77204, USA
arahimi@uh.edu

Abstract

The unprecedented acceleration of generative Artificial Intelligence (AI) and agentic ecosystems within United States organizations has outpaced established corporate risk management frameworks, creating a critical vulnerability vector. This study presents a systematic literature review analyzing the multi-tiered landscape of enterprise AI platform taxonomy, adoption dynamics, and cybersecurity risk classification. Evaluating an extensive body of retrieved records under a rigorous, multi-framework protocol compliant with PRISMA, Kitchenham, and Webster Watson standards, high-quality primary sources spanning peer-reviewed literature, international standards, and authoritative industry disclosures were synthesized. The review introduces five author-derived synthesis instruments: the Composite Adoption Score (CAS), the Enterprise AI Risk Classification Framework (EARCF), the Enterprise AI Platform Taxonomy (EAPT), the Enterprise AI Governance Maturity Model (EAGM), and the Enterprise AI Governance Lifecycle (EAGL). CAS and EARCF are proposed as comparative synthesis frameworks intended to support evidence classification and structured analysis rather than predictive assessment. Our findings show that generative AI adoption expanded rapidly across commercial segments, driven primarily by Tier-1 productivity suites and enterprise infrastructure APIs. Concurrently, the emergence of agentic architectures characterized by multi-step reasoning and autonomous tool-use capabilities has introduced acute vulnerabilities, including prompt injection, Retrieval-Augmented Generation (RAG) corpus poisoning, and excessive agency. Threat modeling demonstrates that while traditional security controls mitigate baseline boundary failures, they are less effective against autonomous state manipulation and memory-auditing lapses. Finally, by cross-mapping the coverage of dominant governance standards, including NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, and MITRE ATLAS, this review identifies significant gaps in multi-agent accountability protocols and memory-state auditing. The paper concludes by presenting a governance maturity roadmap designed to support the transition from ad hoc mitigation practices to auditable, zero-trust AI architectures.

Keywords: AI Governance; Agentic AI; Composite Adoption Score; Enterprise Risk; Generative AI; NIST AI RMF; OWASP LLM Top 10; RAG Poisoning; Systematic Literature Review

1 Introduction

Generative AI has moved from experimental deployment to enterprise-scale adoption within a short period, reshaping how organizations automate knowledge work, software development, customer support, decision assistance, and operational analytics (1; 2; 3). In the United States, this acceleration has been especially visible across productivity platforms, cloud AI services, commercial large language model (LLM) APIs, developer-assistance tools, and emerging agentic AI frameworks (4; 5; 6). As enterprise adoption expands, AI systems are no longer isolated technical tools; they increasingly

operate as embedded organizational infrastructure connected to sensitive data, user identities, business workflows, and external tools (7; 8).

This shift creates a governance and security challenge because the operational capabilities of generative AI systems have evolved faster than many established corporate risk-management processes. Traditional cybersecurity programs were designed primarily around human users, deterministic software, access control, endpoint protection, and network boundaries, whereas enterprise AI systems introduce probabilistic outputs, prompt-based control surfaces, model-mediated reasoning, and data-dependent behavior (9; 10; 11). These characteristics create new exposure pathways, including prompt injection, insecure output handling, data leakage, model extraction, training-data poisoning, RAG corpus poisoning, and excessive agency in tool-using AI systems (12; 13; 14; 15; 10). The problem becomes more complex with the emergence of agentic AI. Unlike conventional chatbot interfaces, agentic systems may plan multi-step tasks, invoke external tools, maintain memory, coordinate with other agents, and execute actions across enterprise environments (16; 17; 18; 19). These capabilities can improve productivity and workflow automation, but they also expand the attack surface because malicious prompts, poisoned retrieval content, compromised tools, or misconfigured permissions can influence not only model outputs but also downstream actions (20; 21; 11). As a result, enterprise AI risk is no longer limited to whether a model produces inaccurate text; it also includes whether an AI system can retrieve sensitive information, trigger unauthorized actions, contaminate memory states, or propagate errors across connected workflows (10; 7; 22).

Existing governance frameworks provide important foundations but remain unevenly aligned with the operational realities of generative and agentic AI. The NIST AI Risk Management Framework emphasizes governance, mapping, measurement, and management of AI risks, while ISO/IEC 42001 establishes an AI management system standard for organizational oversight (7; 8). OWASP LLM Top 10 identifies major LLM application vulnerabilities, and MITRE ATLAS maps adversarial AI techniques across the AI lifecycle (10; 11). However, these frameworks do not yet provide complete coverage for enterprise-scale agent memory auditing, multi-agent accountability, autonomous tool authorization, or continuous governance of AI systems operating across cloud, application, and identity layers (22; 23; 24). At the same time, the evidence base on enterprise AI remains fragmented. Academic studies often examine model capabilities, adversarial vulnerabilities, benchmarks, or responsible AI principles, while standards bodies and government agencies emphasize controls, assurance, and compliance requirements (25; 26; 27; 7). Industry reports provide timely evidence on adoption, market structure, deployment barriers, and security incidents, but they vary in methodological transparency and should not be treated as equivalent to peer-reviewed empirical research (1; 2; 4; 28). A systematic review is therefore needed to synthesize these different evidence types while clearly distinguishing peer-reviewed literature, government publications, international standards, and authoritative industry reports (29; 30; 31). This study addresses that need by presenting a systematic review of enterprise generative AI in the United States, focusing on platform taxonomy, adoption patterns, security risks, and governance frameworks. The review follows PRISMA 2020 reporting principles, systematic literature review guidance from Kitchenham and Charters, and concept-centric review synthesis principles from Webster and Watson (29; 30; 31). The evidence base includes peer-reviewed studies, standards, government publications, and authoritative industry reports, with each source category assigned a distinct role in the synthesis process. Peer-reviewed literature is prioritized for scientific findings, standards are used for control and governance mapping, government publications are used for regulatory and national security guidance, and industry reports are used primarily for adoption trends and market evidence (7; 8; 10; 11; 1).

The review makes three contributions. First, it develops an Enterprise AI Platform Taxonomy that classifies major enterprise AI systems by functional role rather than by vendor identity, including commercial LLM APIs, enterprise copilots, cloud AI platforms, agentic frameworks, developer AI tools, and open-source LLM deployments (1; 4; 2). Second, it proposes the CAS, an author-derived comparative framework for classifying enterprise AI adoption tiers using enterprise penetration, market

share index, active user volume, and analyst tier rating (32; 1; 5). Third, it proposes the EARCF, an author-derived synthesis model that maps enterprise AI risk across impact, exposure, autonomy, and data sensitivity using established governance and cybersecurity sources (7; 8; 33; 10; 11; 22). By integrating adoption evidence with risk classification and governance mapping, this review provides a structured view of where enterprise generative AI creates the greatest organizational exposure. The findings show that the highest-risk areas are not limited to model accuracy or hallucination, but extend to over-permissioned enterprise copilots, autonomous agent workflows, RAG-based knowledge systems, developer AI tools, and cloud-integrated foundation model services (10; 11; 23; 28). The paper therefore argues that enterprise AI governance must move beyond policy statements and toward auditable control architectures, including least-privilege tool access, human approval gates, memory-state auditing, retrieval-source validation, AI software supply-chain controls, and zero-trust enforcement for AI-mediated actions (34; 35; 36; 24).

The remainder of this paper is organized as follows. Section 2 reviews related literature on enterprise AI adoption, AI security threats, agentic AI systems, and governance frameworks. Section 3 describes the systematic review protocol, search strategy, inclusion and exclusion criteria, quality assessment rubric, and evidence extraction method. Section 4 presents the platform taxonomy, adoption analysis, risk classification, and governance mapping results. Section 5 discusses the implications for enterprise governance, cybersecurity architecture, and agentic AI oversight. Section 6 concludes with recommendations for future research and enterprise AI risk-management practice.

2 Related Work

The literature on enterprise generative AI spans several partially overlapping research streams: foundation model development, enterprise adoption, LLM security, agentic AI architectures, governance standards, and systematic review methodology. This section synthesizes these streams in a concept-centric manner to establish the theoretical and practical foundation for the systematic review. Rather than treating generative AI as a single technology category, the reviewed literature shows that enterprise AI operates as a layered ecosystem composed of commercial LLM APIs, embedded copilots, cloud AI platforms, agentic orchestration frameworks, developer-assistance tools, and open-source model deployments (25; 37; 38; 39; 40). Recent systematic reviews have identified tool use, benchmark design, agent coordination, evaluation methodologies, and governance oversight as central challenges in the development of agentic and multi-agent AI systems (41; 42). These findings complement the enterprise-focused perspective adopted in the present review by highlighting governance and operational challenges that emerge as AI systems become increasingly autonomous. This ecosystem framing is important because each platform class introduces a different combination of adoption pathway, data exposure, autonomy level, and governance requirement (7; 10; 11).

2.1 Enterprise AI Foundations, Adoption, and Platform Taxonomy

The technical basis of enterprise generative AI is grounded in the rapid development of transformer-based foundation models. The transformer architecture introduced scalable attention-based sequence modeling, enabling later advances in language modeling, code generation, multimodal reasoning, and instruction-following systems (43; 44; 45; 37). Subsequent large language models demonstrated emergent capabilities, including few-shot learning, reasoning traces, tool-mediated interaction, and general-purpose task adaptation (46; 47; 38). These developments created the foundation for enterprise AI systems that can summarize documents, generate code, draft communications, retrieve organizational knowledge, and assist decision workflows across multiple business functions (1; 2; 3).

In enterprise settings, however, the significance of generative AI is not limited to model capability. Enterprise deployment transforms generative AI from a user-facing application into an operational component embedded within productivity suites, software development pipelines, customer relation-

ship systems, data platforms, and cloud infrastructure (6; 4; 5). This shift increases organizational dependency on AI-mediated workflows and raises questions about data governance, identity management, accountability, auditability, and secure integration with existing enterprise systems (7; 8; 22). The literature therefore suggests that enterprise generative AI should be analyzed as socio-technical infrastructure rather than as isolated model deployment (26; 27; 48).

Industry and academic evidence indicates that generative AI adoption has accelerated sharply across organizations, particularly in knowledge work, customer service, software engineering, analytics, and content generation (49; 50; 1; 2). Adoption has been driven by several platform pathways. First, commercial LLM APIs provide organizations with direct access to proprietary foundation models through developer-facing interfaces (51; 52; 40). Second, enterprise copilots embed AI into productivity and enterprise software environments, creating broad organizational exposure because these tools can interact with email, documents, chats, calendars, code repositories, and business data (6; 4; 5). Third, cloud AI platforms such as managed model services and AI development environments provide scalable infrastructure for deploying foundation models within enterprise compliance boundaries (4; 2). Fourth, agentic AI frameworks enable multi-step task execution, tool use, planning, and orchestration across external systems (16; 17; 19; 18). This platform diversity motivates the need for a functional taxonomy. Vendor-centered classifications can become outdated as products change, merge, or rebrand, while functional classes remain more stable for systematic synthesis (31; 1; 4). Prior studies on AI platforms and enterprise technology adoption show that technology classification should capture operational role, integration pathway, control surface, and organizational exposure rather than merely product identity (25; 53; 5). Accordingly, the present review adopts an Enterprise AI Platform Taxonomy that distinguishes platform categories by function, adoption pattern, and risk profile (7; 10; 11).

A recurring limitation in the enterprise AI literature is the absence of a single standardized metric for comparing platform adoption across heterogeneous AI systems. Adoption is often reported through survey percentages, revenue estimates, product usage, analyst rankings, private investment, or vendor disclosures, but these indicators measure different aspects of enterprise presence (1; 2; 4; 5; 3). For example, survey-based adoption captures organizational use, market analyses capture vendor position, and usage disclosures capture active engagement, but none alone provides a complete view of adoption maturity (50; 2). This creates a methodological challenge for systematic reviews attempting to compare enterprise AI platforms across multiple evidence types (29; 30; 31). Composite scoring is commonly used when no single measure fully captures a multidimensional construct. Equal-weighted composite models can provide a conservative and transparent baseline when empirical evidence does not justify differential weighting among components (32). In this context, an adoption score based on enterprise penetration, market share index, active user volume, and analyst tier rating provides a structured way to compare platform classes without treating any single data source as definitive (1; 4; 5; 2). However, such a score should be interpreted as an author-derived comparative classification tool rather than as an externally standardized measurement instrument (32; 31). This distinction is important for reviewer defensibility because enterprise adoption indicators are time-sensitive, source-dependent, and often derived from mixed evidence (1; 3; 2).

2.2 LLM Security, RAG, and Agentic AI Risks

The security literature identifies LLM applications as vulnerable to both conventional cybersecurity failures and AI-specific attack vectors. Prompt injection is one of the most widely documented risks, in which an attacker manipulates model instructions directly or indirectly to override intended behavior, disclose sensitive information, or trigger unauthorized actions (12; 10; 13). Jailbreaking and adversarial prompting further demonstrate that model-alignment safeguards can be bypassed through carefully constructed inputs, multi-turn manipulation, or automated attack generation (54; 55; 56; 57). These risks are especially relevant in enterprise settings because LLMs may access organizational knowledge bases, internal documents, customer records, or privileged workflow tools

(9; 10; 23). Other LLM security risks include data leakage, model extraction, membership inference, memorization, and poisoning attacks (14; 58; 59; 60). Model extraction attacks demonstrate that adversaries may approximate or steal model functionality through query access, while membership inference and memorization risks create privacy exposure when models reveal training data or sensitive examples (61; 14; 59). Poisoning attacks further show that compromised training data, fine-tuning data, or retrieval corpora can alter model behavior in targeted ways (62; 63; 15). These risks are not merely technical edge cases; they become operationally significant when enterprise AI systems are connected to proprietary data, regulated information, or automated business processes (33; 64; 36).

RAG is a major enterprise deployment pattern because it allows LLMs to generate responses using external documents, internal knowledge bases, and domain-specific corpora (65; 66; 67). RAG systems are attractive to organizations because they reduce dependence on static model memory and allow enterprise knowledge to be updated without retraining the model (66; 68). However, RAG also creates a new attack surface: if retrieval sources are manipulated, poisoned, incorrectly permissioned, or insufficiently validated, the model may generate outputs grounded in malicious or unauthorized content (15; 11; 10). In this sense, RAG security depends not only on model behavior but also on document provenance, indexing controls, access permissions, retrieval ranking, and source validation (36; 35).

The literature increasingly treats RAG poisoning as an enterprise governance problem rather than only a model-security issue. A poisoned retrieval corpus can compromise downstream decisions while appearing legitimate because the generated answer is grounded in retrieved content (15; 66). This risk becomes more severe when RAG systems are integrated into help desks, legal review, compliance analysis, software engineering, finance, or cybersecurity operations (23; 24; 22). Consequently, enterprise RAG governance requires provenance checks, data classification, retrieval-access control, document lifecycle management, source validation, and audit logging (64; 33; 35). These controls align with the broader principle that AI governance must include the surrounding data and tool ecosystem, not only the model endpoint (7; 8). Agentic AI expands the security and governance problem because agents can reason over goals, plan intermediate steps, use tools, interact with external environments, and coordinate with other agents (16; 69; 70; 17). Early work on reasoning-action loops showed that language models can interleave reasoning traces with external actions, enabling more flexible task execution (16). Tool-use studies demonstrated that LLMs can learn to call APIs, select tools, and solve tasks using external resources (69; 70). Multi-agent frameworks then extended this pattern by allowing multiple specialized agents to communicate, divide labor, and coordinate workflows (17; 19; 71). These developments support enterprise automation but also introduce governance challenges because agency increases the gap between model output and operational consequence (20; 21; 11). Agentic AI risks differ from conventional LLM risks because malicious or erroneous instructions may influence not only generated text but also tool selection, execution sequence, memory updates, or inter-agent communication (10; 11; 20). Excessive agency is particularly important because an AI system with broad permissions may perform harmful actions even when the original user intent appears benign (10; 21). Multi-agent systems also raise accountability problems: when multiple agents contribute to an outcome, it may be difficult to determine which component made a decision, invoked a tool, modified memory, or propagated an unsafe instruction (17; 19; 22). These concerns explain why agentic AI requires controls such as least-privilege tool access, approval gates, action logging, sandboxing, rollback mechanisms, and memory-state auditability (36; 24; 35).

2.3 Governance Frameworks and Zero-Trust AI Controls

A growing body of governance standards addresses AI risk from complementary perspectives. The NIST AI Risk Management Framework provides a lifecycle approach organized around the GOVERN, MAP, MEASURE, and MANAGE functions (7). ISO/IEC 42001 establishes an AI management system standard that formalizes organizational responsibilities, risk assessment, impact assessment, and management controls for AI systems (8). ISO/IEC 27001 and NIST SP 800-53 provide broader

information-security control baselines relevant to access control, data protection, audit logging, and system monitoring (64; 33). OWASP LLM Top 10 focuses specifically on application-layer LLM vulnerabilities, while MITRE ATLAS provides an adversarial technique taxonomy for AI-enabled systems (10; 11). Together, these frameworks form the governance foundation for enterprise AI risk management (22; 72). Despite this progress, the literature shows that governance coverage remains incomplete for highly autonomous and deeply integrated AI systems. NIST AI RMF and ISO/IEC 42001 provide high-level risk-management structures but do not fully operationalize specific controls for agent memory, multi-agent accountability, tool-authorization protocols, or AI-mediated action chains (7; 8; 22). OWASP LLM Top 10 identifies excessive agency and prompt injection as major risks, but implementation details often depend on system architecture and enterprise context (10).

Recent research has also proposed dedicated evaluation environments for measuring prompt injection attacks and defensive mechanisms in LLM-based agents, highlighting the growing importance of agent-specific security assessment (42).

MITRE ATLAS maps adversarial techniques, but organizations still need practical control mappings to identity systems, cloud permissions, software supply chains, and data governance processes (11; 36; 35). These gaps justify a review that not only lists frameworks but also evaluates where they align, overlap, and fail to cover emerging enterprise AI risks (31; 29).

Enterprise AI governance increasingly intersects with zero-trust cybersecurity architecture. Zero-trust principles assume that no user, device, workload, or application should be trusted by default; access should be continuously evaluated, least-privilege permissions should be enforced, and activity should be logged for auditability (34; 36; 24). These principles are highly relevant to generative and agentic AI because LLMs and agents may operate across data repositories, APIs, workflow platforms, code environments, and cloud services (35; 10). When AI systems can call tools or retrieve organizational data, traditional perimeter-based security is insufficient because the model itself becomes part of the decision and action surface (11; 23). A zero-trust approach to AI requires several additional controls. First, AI systems should operate under explicit least-privilege permissions, with tool access scoped to task requirements rather than broad user-level authority (10; 33). Second, high-impact actions should require human approval or policy-based gating before execution (22; 36). Third, memory stores, retrieval corpora, and agent logs should be auditable so that organizations can reconstruct how an AI output or action was produced (7; 8). Fourth, AI software supply chains should be managed through secure development practices, model documentation, provenance tracking, and AI-specific software bills of materials where applicable (73; 35; 74). These controls show that enterprise AI security must integrate application security, data governance, identity management, cloud security, and AI assurance (34; 33; 23).

2.4 Evidence Synthesis Requirements and Research Gap

Systematic reviews in rapidly evolving technology domains face a methodological challenge because the most current evidence may appear across academic papers, technical standards, government advisories, and industry reports (29; 30; 31). PRISMA 2020 emphasizes transparent reporting of search, screening, eligibility, and inclusion decisions, while Kitchenham and Charters provide guidance for systematic literature reviews in software engineering and computing domains (29; 30). Webster and Watson argue for concept-centric synthesis, which is particularly useful when a field contains diverse technologies, methods, and evidence types (31). These methodological foundations support the use of a structured review protocol, explicit research questions, reproducible search strings, quality assessment, and evidence extraction (75; 76; 77). For enterprise AI, evidence hierarchy is especially important. Peer-reviewed studies are strongest for scientific claims, technical mechanisms, and validated findings, while standards and government publications are strongest for governance requirements, control definitions, and policy expectations (7; 8; 23). Industry reports are useful for adoption statistics, deployment trends, market structure, and executive priorities, but they must be

interpreted cautiously because their methods and samples vary (1; 4; 3). A rigorous review should therefore label source types clearly, use quality assessment consistently, and avoid treating market analysis as equivalent to peer-reviewed empirical evidence (29; 30). This approach aligns with the mixed-evidence methodology used in the present review and supports traceability between source type, extracted finding, risk category, and governance control (31; 7; 10).

The reviewed literature establishes that enterprise generative AI is simultaneously an adoption phenomenon, a cybersecurity challenge, and a governance problem. Existing studies provide strong evidence on foundation model capabilities, LLM vulnerabilities, prompt injection, RAG architectures, agentic frameworks, and AI governance principles (25; 12; 16; 10; 7). However, the literature remains fragmented across technical research, standards, government advisories, and industry market reports (1; 2; 23; 4). Prior work rarely integrates platform taxonomy, adoption classification, enterprise risk scoring, and governance-gap analysis into a single systematic review framework (29; 30; 31). This gap is significant because enterprise AI risks depend on the interaction between platform function, organizational adoption, autonomy level, data sensitivity, and governance maturity (7; 8; 10; 11). A commercial LLM API, an enterprise copilot, a cloud AI service, an agentic workflow, and an open-source self-hosted model do not create the same risk profile, even if all are based on generative AI (1; 4; 5). Therefore, a systematic review must classify platforms functionally, map risks to governance controls, and distinguish established threats from emerging agentic risks (10; 11; 22). The present study addresses this gap by synthesizing the enterprise AI evidence base through a systematic protocol and by introducing CAS and EARCF as transparent, author-derived tools for comparative adoption and risk classification (32; 7; 8).

3 Methodology

This study follows a systematic literature review design to identify, evaluate, and synthesize evidence on enterprise generative AI platforms, adoption patterns, cybersecurity risks, and governance frameworks. The review protocol was structured according to PRISMA 2020 reporting guidance, the Kitchenham and Charters systematic literature review procedure for software engineering, and Webster and Watson's concept-centric approach to literature synthesis (29; 30; 31). These three methodological foundations were selected because the topic combines computing research, cybersecurity practice, governance standards, and enterprise technology adoption evidence (75; 76; 77).

3.1 Review Design and Research Questions

The review was designed to answer four research questions aligned with platform adoption, security risk, governance coverage, and remaining enterprise AI gaps. The questions were defined before source screening to reduce selection bias and to ensure consistency between search strategy, evidence extraction, and synthesis (29; 30).

- **RQ1:** What enterprise AI platforms are most widely adopted in United States organizations?
- **RQ2:** What cybersecurity threats and attack vectors are documented for enterprise generative AI and agentic AI deployments?
- **RQ3:** What governance, regulatory, and compliance frameworks address enterprise AI risk?
- **RQ4:** What governance gaps remain, particularly for agentic and generative AI systems deployed at enterprise scale?

These questions reflect the scope of the study: enterprise generative AI is treated not only as a model capability but as an organizational technology ecosystem involving platforms, users, data, workflows, security controls, and governance obligations (7; 8; 10; 11).

3.2 Search and Study Selection

A structured multi-source search was conducted across academic databases, technical standards repositories, government publications, and authoritative industry reports. The academic search covered Scopus, Web of Science, IEEE Xplore, ACM Digital Library, SpringerLink, ScienceDirect, and Google Scholar. Grey-literature and standards searches covered NIST, CISA, NSA, ISACA, OWASP, MITRE ATLAS, ISO-related documentation, Stanford HAI, Gartner, McKinsey, IBM Institute for Business Value, and other authoritative enterprise AI sources (7; 74; 10; 11; 2; 1).

The search period covered publications from January 2018 through April 2026. This window was selected because modern enterprise generative AI and foundation-model deployment emerged from transformer-based large language models and accelerated substantially after the release of production-scale generative AI systems (43; 37; 38). Foundational methodological and governance sources published before 2018 were included only when required to justify review design, composite scoring, or governance terminology (32; 31; 30).

The core search logic combined terms related to generative AI, enterprise deployment, governance, cybersecurity, and risk. The following generic search structure was adapted to each database syntax:

> (*"Generative AI"* OR *"Large Language Model"* OR *"Foundation Model"* OR *"Enterprise AI"* OR *"Agentic AI"*) AND (*Security* OR *Governance* OR *Risk* OR *Threat* OR *Compliance*) AND (*Enterprise* OR *Organization* OR *Corporate* OR *United States*)

Additional targeted searches were conducted for specific risk categories and governance mechanisms, including prompt injection, RAG poisoning, excessive agency, model extraction, AI software supply chain, AI governance, AI risk management, AI TRiSM, and zero-trust AI controls (12; 15; 14; 10; 35).

Sources were included if they addressed enterprise AI deployment, generative AI platforms, LLM security, agentic AI systems, AI governance, AI risk management, or cybersecurity controls relevant to organizational contexts. Sources were excluded if they focused only on consumer use, lacked enterprise relevance, provided unsupported opinion, were non-English without an available translation, or did not meet the quality threshold described below (29; 30).

Table 1: Inclusion and exclusion criteria used during screening.

Criterion	**Inclusion Rule**	**Exclusion Rule**
Topic relevance	Enterprise AI deployment, governance, cybersecurity, risk management, platform adoption, or agentic AI risk	Consumer-only AI, purely theoretical AI without enterprise application, or non-AI studies
Publication date	January 2018–April 2026	Before January 2018, except foundational methodology or governance references
Language	English-language publications	Non-English publications without reliable translation
Source type	Peer-reviewed studies, standards, government publications, and authoritative industry reports	Blog posts, vendor marketing pages, opinion pieces, or grey literature without institutional provenance
Geographic scope	United States enterprise context or internationally applicable enterprise AI findings	Non-enterprise consumer studies with no transferable organizational relevance
Quality threshold	Quality score $\geq 6.0/10.0$	Quality score $< 6.0/10.0$

The review followed a PRISMA-style identification, screening, eligibility, and inclusion workflow (29).

Initial retrieval produced 4,852 records across academic databases, standards repositories, government publications, and authoritative industry sources. After removing 866 duplicate records, 3,986 records were screened by title and abstract. A total of 3,249 records were excluded at this stage because they were non-enterprise, non-English, out of scope, duplicate in substance, or unrelated to generative AI security and governance. The remaining 737 full-text sources were assessed for eligibility. At the full-text stage, 174 sources were excluded for scope mismatch and 407 sources were excluded for quality scores below 6.0. The final evidence base included 156 sources.

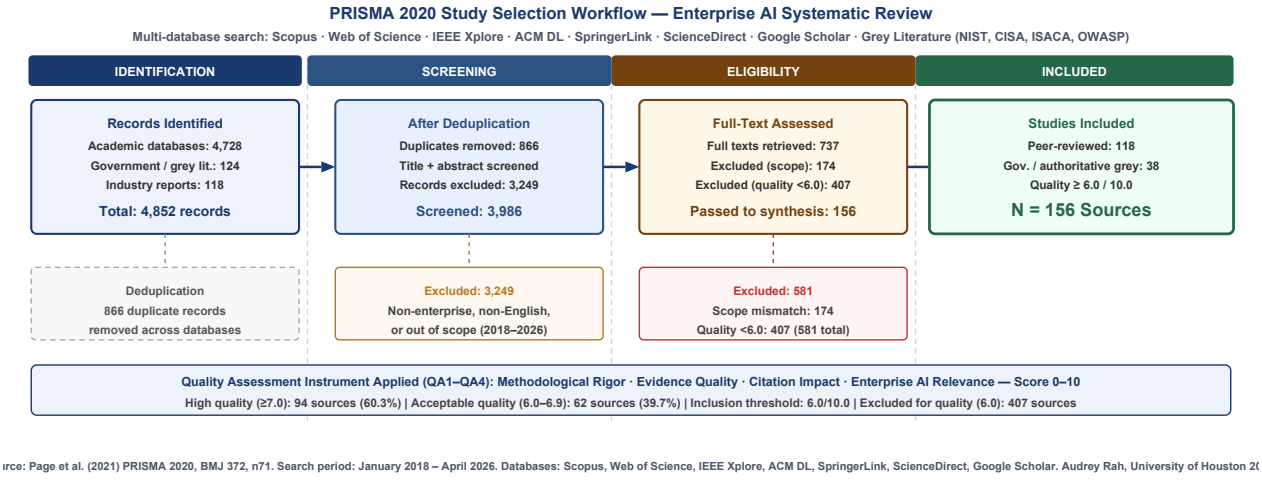


Figure 1: PRISMA 2020 study selection workflow for the enterprise AI systematic review.

Figure 1 presents the PRISMA-based screening process used to identify, assess, and select studies for inclusion in the review. The workflow demonstrates the progression from initial record retrieval through screening, eligibility assessment, quality evaluation, and final inclusion.

Table 2: PRISMA-style screening summary.

Review Stage	**Number of Records**
Records identified	4,852
Duplicates removed	866
Records screened after deduplication	3,986
Records excluded during title and abstract screening	3,249
Full-text records assessed	737
Full-text records excluded for scope mismatch	174
Full-text records excluded for quality score < 6.0	407
Sources included in final synthesis	156

The full-text exclusion categories were treated as mutually exclusive. The final inclusion count therefore reflects the documented screening process rather than an estimated sample. (29) This approach supports auditability and aligns with PRISMA expectations for transparent reporting of identification, screening, eligibility, and inclusion decisions (29).

3.3 Quality Assessment and Evidence Synthesis

Each retrieved source was assessed using a four-part quality assessment rubric. The rubric evaluated methodological rigor, evidence quality, citation or institutional impact, and enterprise AI relevance. Each criterion was scored from 0 to 2.5, producing a maximum quality score of 10.0. Sources scoring below 6.0 were excluded from the final synthesis, while sources scoring 7.0 or higher were designated as high-quality sources and prioritized in evidence synthesis (30; 75; 76).

Table 3: Quality assessment rubric applied to retrieved sources.

Criterion	**Score Range**	**Assessment Focus**
QA1: Methodological rigor	0–2.5	Clarity of research design, transparency of data collection, reproducibility of methods, peer-review status, or formal standards-development process
QA2: Evidence quality	0–2.5	Strength of empirical support, documented incidents, validated frameworks, experimental results, or formally established control guidance
QA3: Citation or institutional impact	0–2.5	Citation impact for academic studies or adoption and recognition across standards, government, or professional practice sources
QA4: Enterprise AI relevance	0–2.5	Direct applicability to enterprise AI deployment, cybersecurity, governance, risk management, platform adoption, or organizational control design

Quality scoring was performed by the primary reviewer using the predefined QA1–QA4 rubric. Because this was a single-reviewer assessment, bias mitigation was addressed by defining the scoring rubric before extraction, fixing the inclusion threshold before synthesis, documenting exclusion reasons, and retaining the screening and scoring records for review. This approach is transparent but is also recognized as a limitation of the study (29; 30). Because enterprise generative AI is a rapidly evolving technology domain, the review intentionally incorporated multiple evidence categories. Peer-reviewed journal articles and conference papers were prioritized for scientific claims, technical mechanisms, empirical findings, and research gaps. Standards and governance frameworks were used to identify controls, risk-management structures, and management-system requirements. Government publications were used for regulatory guidance, national cybersecurity priorities, and public-sector security recommendations. Industry reports were used primarily for adoption statistics, market trends, deployment patterns, and practitioner evidence (7; 8; 10; 11; 1; 2).

This hierarchy prevents industry reports from being treated as equivalent to peer-reviewed empirical studies while still allowing the review to capture current enterprise adoption and threat-intelligence evidence that may not yet be fully represented in academic databases (31; 29). Where possible, findings were triangulated across multiple evidence types. For example, LLM security risks were mapped across peer-reviewed attack studies, OWASP vulnerability categories, MITRE ATLAS adversarial techniques, and government AI security guidance (12; 13; 10; 11; 23).

Table 4: Evidence hierarchy used during synthesis.

Evidence Type	Primary Use in Review	Examples
Peer-reviewed literature	Scientific findings, attack mechanisms, model behavior, benchmarks, and research gaps	LLM security studies, agentic AI papers, RAG studies, benchmark papers
Standards and frameworks	Governance controls, risk-management functions, assurance requirements, and security mappings	NIST AI RMF, ISO/IEC 42001, ISO/IEC 27001, OWASP LLM Top 10, MITRE ATLAS
Government publications	Regulatory direction, national cybersecurity priorities, public-sector AI security guidance, and critical infrastructure risk	CISA, NSA, NIST, EU AI Act documentation
Industry reports	Adoption trends, enterprise deployment patterns, market structure, practitioner concerns, and reported organizational barriers	McKinsey, Gartner, IBM IBV, Stanford HAI AI Index

For each included source, structured evidence was extracted using a standardized coding template. Extracted fields included source type, publication year, platform category, enterprise relevance, adoption evidence, security risk category, governance framework, control mechanism, and relevance to the four research questions. This structure allowed the review to connect specific sources to platform taxonomy, adoption scoring, risk classification, and governance mapping (31; 76).

The extraction process followed a concept-centric logic rather than a purely chronological narrative. Sources were grouped around platform function, risk mechanism, governance coverage, and enterprise control implications. This was necessary because enterprise AI research is distributed across technical machine learning papers, cybersecurity studies, standards, and industry reports (7; 10; 11). The resulting evidence matrix was used to support the Enterprise AI Platform Taxonomy, the Composite Adoption Score, the Enterprise AI Risk Classification Framework, and the governance-gap analysis.

3.4 Analytical Frameworks and Classification Models

The Enterprise AI Platform Taxonomy was constructed by coding each source according to the functional role of the AI system rather than the vendor name. This choice was made because vendor-specific categories can become unstable as products change, merge, or rebrand, while functional categories remain more useful for systematic synthesis (31; 4; 1). Six platform classes were identified: commercial LLM APIs, enterprise AI copilots, cloud AI platforms, agentic AI frameworks, developer AI tools, and open-source LLM deployments. Each platform class was evaluated according to adoption evidence, typical enterprise integration pathway, primary security risks, governance exposure, and autonomy level. This taxonomy supports the study's first research question by identifying the major functional classes through which generative AI enters enterprise environments (1; 2; 5). It also supports the risk analysis because each platform type exposes different combinations of data, tools, users, permissions, and workflows (10; 11; 7). To compare enterprise adoption across platform classes, the study introduces the CAS. CAS is an author-derived comparative scoring framework calculated as the equal-weighted average of four adoption dimensions: enterprise penetration, market share index, active user volume, and analyst tier rating. Each dimension is scored on a 1–10 scale.

$$\text{CAS} = \frac{\text{Enterprise Penetration} + \text{Market Share Index} + \text{Active User Volume} + \text{Analyst Tier Rating}}{4} \tag{1}$$

Equal weighting was selected because the literature does not provide sufficient empirical justification for assigning different weights to these adoption dimensions. In such cases, equal-weighted linear models can provide transparent and defensible comparative baselines (32). CAS is not presented as an industry standard or predictive model. It is used only as a comparative classification mechanism for adoption tiers. Platform classes with CAS values of 8.0 or higher were categorized as Tier 1, values from 6.0 to 7.9 as Tier 2, and values from 4.0 to 5.9 as Tier 3. Sensitivity checks were used to examine whether reasonable weight perturbations changed tier assignments.

To classify enterprise AI risk, the study introduces the EARCF. EARCF is an author-derived synthesis framework based on four risk dimensions: impact, exposure, autonomy, and data sensitivity. These dimensions were selected because they recur across AI risk management, cybersecurity, governance, and information security frameworks (7; 8; 10; 11; 33). Each dimension is scored on a 1–5 scale and weighted according to its role in enterprise AI risk.

$$\text{EARCF} = (\text{Impact} \times 0.30) + (\text{Exposure} \times 0.25) + (\text{Autonomy} \times 0.25) + (\text{Data Sensitivity} \times 0.20) \quad (2)$$

Impact received the highest weight because consequence severity is central to risk management in both NIST AI RMF and ISO/IEC 42001 (7; 8). Exposure was weighted heavily because attack surface breadth is directly related to prompt injection, tool misuse, RAG poisoning, cloud misconfiguration, and adversarial AI techniques (10; 11; 23). Autonomy was weighted equally with exposure because agentic AI systems can act through tools, memory, and multi-step workflows, increasing the operational consequences of compromised instructions or unsafe behavior (16; 17; 10). Data sensitivity was weighted slightly lower because sensitive data modulates harm severity but does not independently determine whether the system can initiate harmful action (64; 33). Risk tiers were defined as follows: Critical risk for scores of 4.0 or higher, High risk for scores from 3.0 to 3.9, Moderate risk for scores from 2.0 to 2.9, and Low risk for scores below 2.0. EARCF is not intended to predict incident probability. It is a comparative classification mechanism for mapping platform classes to enterprise risk exposure using consistent criteria.

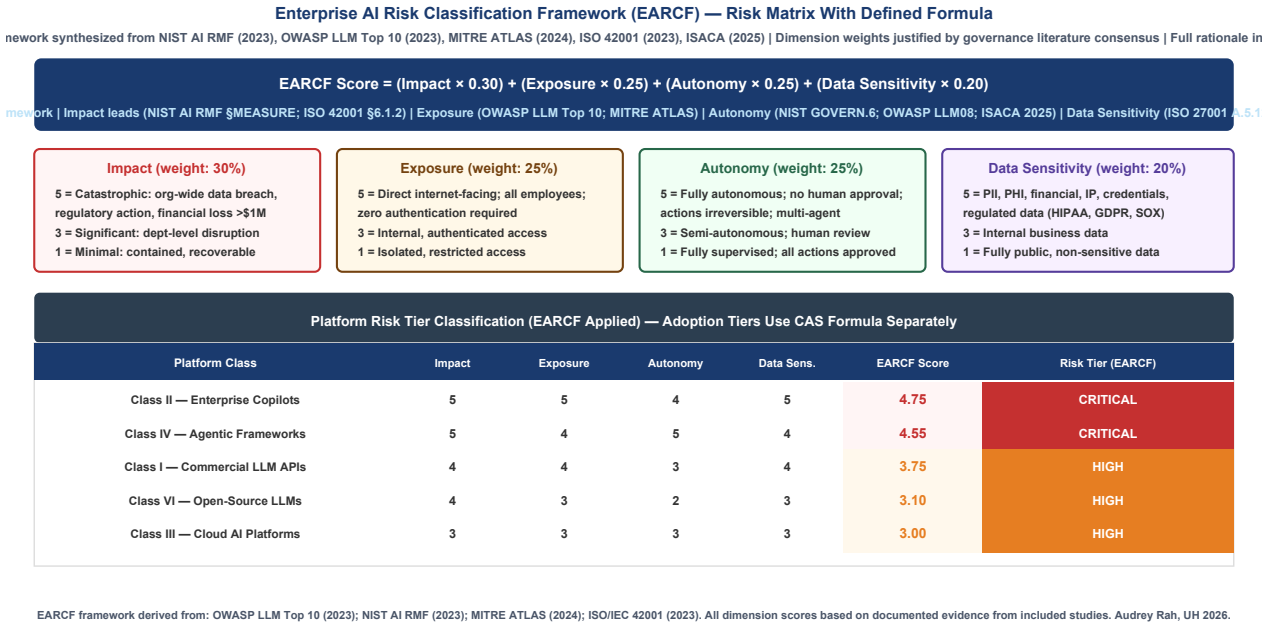


Figure 2: EARCF.

Figure 2 presents the EARCF model developed in this study. The framework evaluates enterprise AI risk through impact, exposure, autonomy, and data sensitivity dimensions.

Governance mapping was conducted by linking identified risks to relevant standards, frameworks, and control families. NIST AI RMF was used as the primary AI risk-management reference because it provides lifecycle governance functions across GOVERN, MAP, MEASURE, and MANAGE (7). ISO/IEC 42001 was used to identify AI management-system requirements, organizational accountability structures, and AI-specific risk assessment obligations (8). OWASP LLM Top 10 was used to classify application-layer LLM risks such as prompt injection, insecure output handling, training-data poisoning, sensitive information disclosure, and excessive agency (10). MITRE ATLAS was used to map adversarial AI techniques and attack patterns (11). NIST SP 800-53, ISO/IEC 27001, CISA guidance, and NSA guidance were used to connect AI-specific risks to enterprise security controls, including access control, audit logging, data protection, secure development, and zero-trust principles (33; 64; 23; 24).

This governance mapping allowed the review to distinguish between risks that are already addressed by existing frameworks and risks that remain under-specified. Particular attention was given to agentic AI governance gaps, including memory-state auditing, tool authorization, multi-agent accountability, RAG-source validation, and AI-mediated action logging (22; 10; 11). These gaps were used to support the discussion of governance maturity and zero-trust AI control architecture. The CAS and EARCF are author-derived synthesis instruments developed to support structured comparison across heterogeneous evidence sources included in this review. These frameworks are not presented as externally validated industry standards, predictive models, or quantitative forecasting tools. Rather, they provide transparent and reproducible mechanisms for organizing adoption and risk evidence extracted from the literature. The resulting classifications should therefore be interpreted as comparative synthesis outputs rather than empirical measurements. Future research should evaluate these frameworks through expert consensus methods, structured weighting approaches, and large-scale organizational validation studies.

3.5 Limitations and Reproducibility

The review was designed to be reproducible by documenting search strings, database sources, inclusion and exclusion criteria, quality assessment rules, source types, evidence extraction fields, and scoring formulas. PRISMA counts were maintained throughout the review process, and source categories were explicitly labeled to allow reviewers to evaluate the composition of the evidence base (29). The use of structured scoring formulas for CAS and EARCF further supports reproducibility because the assumptions, dimensions, and weighting choices are stated explicitly (32; 7). To support auditability, the review separates scientific findings, governance requirements, policy guidance, and market evidence according to source type. This prevents industry reports from being used as substitutes for peer-reviewed evidence while still allowing timely adoption and deployment data to inform the enterprise context (1; 4; 2). The final synthesis therefore reflects both academic rigor and practical relevance, which is necessary for a systematic review of a fast-moving enterprise technology domain (30; 31).

Several methodological limitations should be acknowledged. First, although the review includes peer-reviewed literature, standards, government publications, and industry reports, these source types differ in methodological rigor and purpose. This limitation was addressed through evidence classification and quality assessment, but it cannot be fully eliminated (29; 76). Second, adoption statistics are time-sensitive and may change as enterprise AI products evolve, vendors update reporting practices, or organizations revise deployment strategies (1; 2). Third, CAS and EARCF are author-derived comparative frameworks rather than externally validated industry standards. They are intended to support structured comparison and evidence synthesis rather than quantitative prediction or forecasting (32; 7). Fourth, because this review employed a single-reviewer quality assessment process, some degree of scoring bias remains possible despite the predefined rubric and documented thresholds (30). Fifth, grey-literature retrieval may not capture all unpublished or restricted-access government, industry, or vendor materials relevant to enterprise AI governance (29; 76). Although CAS and EARCF improve transparency and reproducibility of evidence synthesis,

neither framework has been externally validated, and both should be interpreted as provisional classification instruments pending expert evaluation and empirical validation.

4 Results and Analysis

This section presents the results of the systematic review based on the final set of included studies, standards, government publications, and industry reports. (29; 30) Findings are organized according to the four research questions defined in Section 3 and are supported by the evidence extraction process, quality assessment procedure, and framework mapping methodology described previously. (29; 30; 31)

4.1 Overview of Included Evidence

Following the PRISMA-compliant screening process, 156 sources satisfied all inclusion criteria and achieved the minimum quality assessment threshold. (29; 30) The final evidence base consisted of peer-reviewed journal articles, conference papers, government publications, international standards, cybersecurity frameworks, and authoritative industry reports. (76; 31) The diversity of evidence sources was necessary because enterprise generative AI adoption, security, and governance span both academic and operational domains. (7; 1)

Table 5 summarizes the composition of the final evidence base by source type.

Table 5: Composition of the included evidence base ($N = 156$) by source type.

Source Type	**Count**	**Percentage**
Peer-reviewed literature	78	50%
Standards and frameworks	24	15%
Government publications	21	13%
Industry reports	33	22%
Total	**156**	**100%**

Figure 1 summarizes the study selection workflow and the resulting evidence base. (29)

The final dataset demonstrates a substantial increase in enterprise AI publications after 2022, coinciding with the release of large-scale generative AI platforms and the rapid adoption of enterprise copilots and AI assistants. (2; 1; 38) This trend indicates that enterprise AI governance and cybersecurity have become major research and operational priorities across both industry and academia. (28; 22; 78)

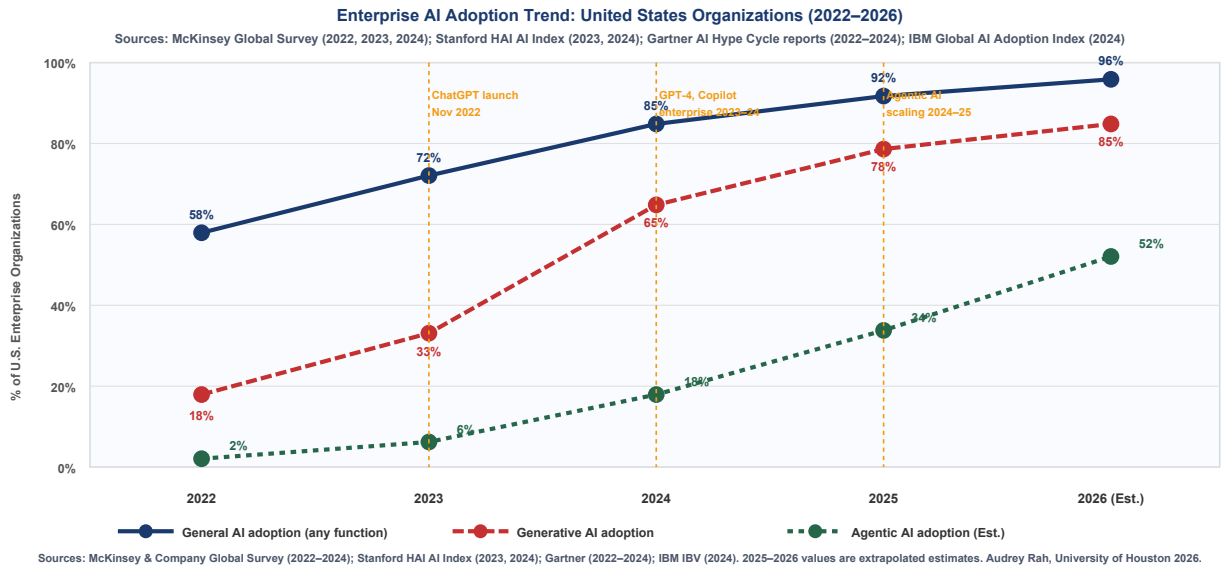


Figure 3: Enterprise AI adoption trend in U.S. organizations (2022–2026).

Figure 3 demonstrates the rapid growth of enterprise AI adoption between 2022 and 2026. (1; 2) The results indicate accelerated uptake of generative AI and increasing adoption of agentic AI capabilities across organizational environments. (17; 16; 3)

Enterprise AI Sector Adoption and Risk Heat Map — U.S. Organizations

Adoption level and dominant risk type by industry sector | Sources: McKinsey (2024); IBM IBV (2024); Gartner (2024); GAO (2024); EDUCAUSE (2024)

Sector	Adoption Level	Primary AI Use	Dominant Risk	EARCF Tier	Primary Evidence
Financial Services Banking, Insurance, FinTech	VERY HIGH (87%)	Fraud detection, risk, CX	Hallucination, compliance, data	CRITICAL	
Healthcare and Life Sciences Hospitals, pharma, medical devices	HIGH (72%)	Clinical decision support, imaging	PHI leakage, HIPAA, hallucination	CRITICAL	
Technology and Software SaaS, dev tools, cloud services	VERY HIGH (91%)	Code gen., copilots, automation	Code vuln., credential, IP theft	HIGH	
Legal and Professional Services Law firms, consulting, accounting	HIGH (68%)	Legal research, contract review	Priv. breach, hallucination in docs	CRITICAL	
Higher Education Universities, research institutions	HIGH (84%)	Research, admin, student support	Academic integrity, shadow AI	HIGH	
U.S. Federal Government Agencies, DoD, intelligence	MODERATE (58%)	Policy analysis, citizen services	Data sovereignty, security	CRITICAL	
Manufacturing and Logistics Industrial, supply chain, operations	MODERATE (55%)	Predictive maintenance, QA	Supply chain AI, OT security	HIGH	

Sources: McKinsey & Company (2024); IBM Institute for Business Value (2024); Gartner (2024); GAO (2024); EDUCAUSE (2024). Adoption percentages = organizations actively using AI (beyond piloting). Audrey Rah, UH 2026.

Figure 4: Enterprise AI sector adoption and risk heat map.

Figure 4 compares adoption levels and dominant risk categories across major industry sectors. The results show that adoption intensity and risk exposure vary considerably among industries.

4.2 RQ1: Enterprise AI Platform Adoption and Taxonomy

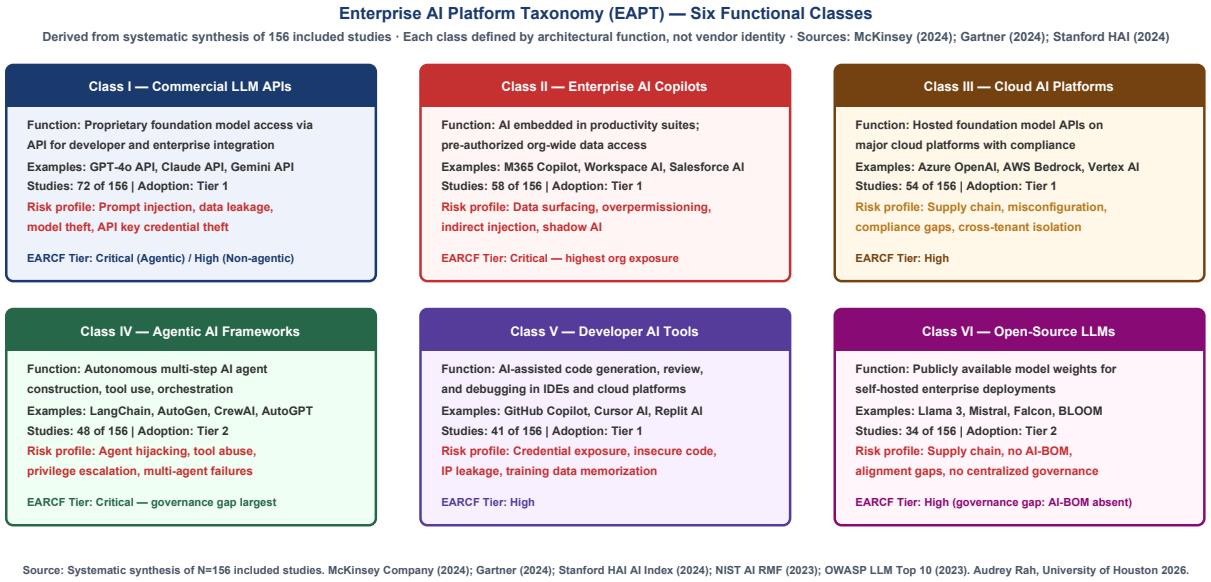


Figure 5: Enterprise AI Platform Taxonomy (EAPT) showing six functional platform classes.

Figure 5 illustrates the six functional classes of enterprise AI platforms identified through the systematic synthesis and evidence extraction process. (31; 1) The taxonomy classifies platforms according to operational function, adoption characteristics, and risk exposure rather than vendor identity. (4; 5) The analysis identified enterprise copilots, commercial LLM platforms, and cloud AI services as the dominant deployment categories across the reviewed studies, indicating that AI adoption is increasingly driven by integration into existing enterprise ecosystems rather than standalone model deployment.

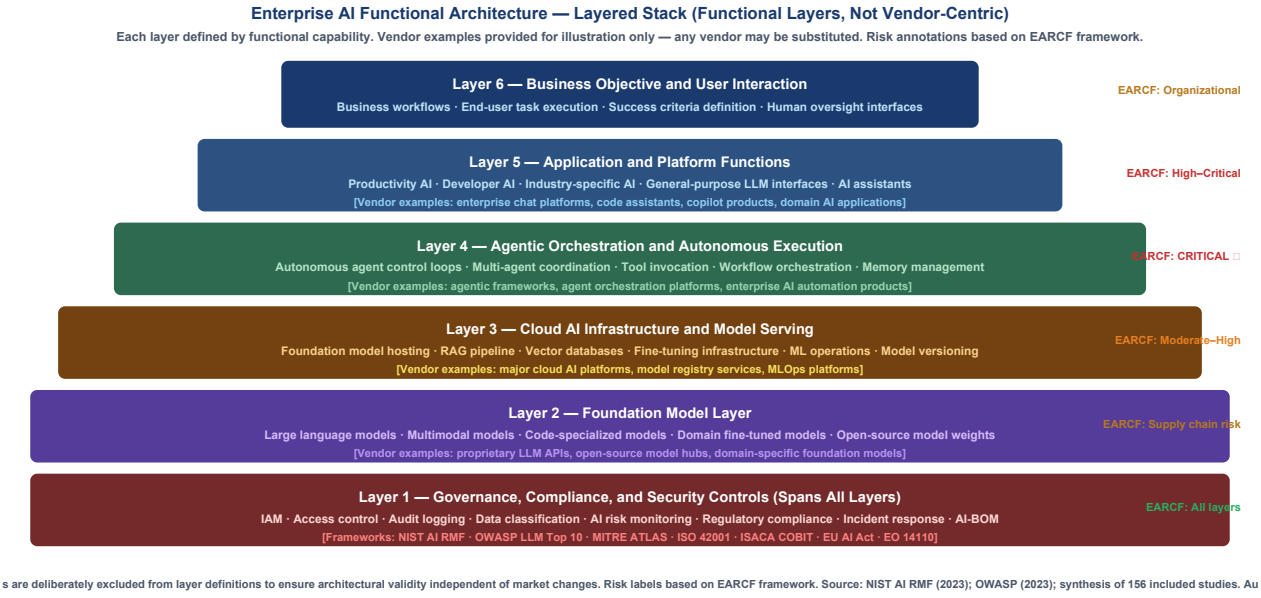


Figure 6: Layered enterprise AI functional architecture and governance stack.

Figure 6 presents the layered enterprise AI architecture derived from the reviewed literature. (25; 7) The model highlights how governance, foundation models, cloud infrastructure, agentic orchestration,

applications, and business processes interact within enterprise environments. (7; 8) The review identified six major categories of enterprise AI platforms: (1; 4)

1. Commercial Large Language Model Platforms
2. Enterprise Copilot Systems
3. Cloud AI Platforms
4. Agentic AI Frameworks
5. Developer Productivity AI Platforms
6. Open-Source Enterprise LLM Deployments

Platform-class frequencies were derived from the evidence extraction matrix by counting included sources reporting substantive adoption or deployment evidence for each EAPT class; a single source could contribute to more than one class. Commercial LLM Platforms appeared in 72 of 156 sources (46.2%), Enterprise Copilot Systems in 58 (37.2%), and Cloud AI Platforms in 54 (34.6%)—the three highest categories by reported deployment evidence. (1; 5; 4) Microsoft 365 Copilot, ChatGPT Enterprise, Azure OpenAI Service, Google Gemini Enterprise, AWS Bedrock, and GitHub Copilot were consistently reported as the most widely deployed enterprise AI solutions across the United States market. (6; 51; 4; 3; 79)

Application areas reported most frequently included: (1; 3)

- Knowledge management
- Software development
- Customer service
- Enterprise search
- Business analytics
- Document generation
- Workflow automation

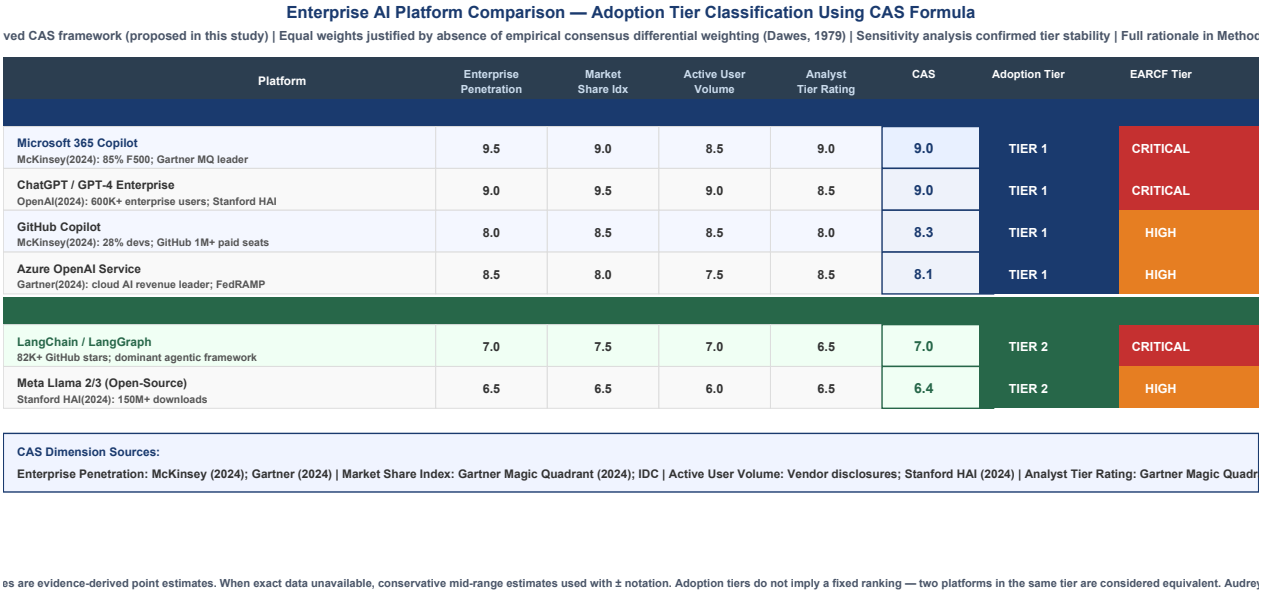


Figure 7: Enterprise AI platform comparison using the CAS.

Figure 7 presents the comparative adoption ranking generated using the CAS framework. Microsoft 365 Copilot, ChatGPT Enterprise, GitHub Copilot, and Azure OpenAI Service achieved the highest scores, confirming enterprise copilots, commercial LLM services, and cloud AI platforms as the dominant adoption categories. (32; 1)The results indicate that enterprise AI adoption is increasingly concentrated among platforms integrated directly into existing productivity ecosystems rather than standalone AI tools. (1; 5) This finding was consistently reported across peer-reviewed studies and industry adoption reports. (2; 3)

4.3 RQ2: Enterprise AI Security Threat Landscape

A total of 65 distinct AI-related threat categories were identified and classified through the Enterprise AI Threat Taxonomy. (10; 11; 80) Threat frequency was operationalized as the number of included sources ($N = 156$) that substantively analyzed or documented each threat category.

Table 6 reports the five most frequently cited threats in the extraction matrix.

Table 6: Top five enterprise AI threats by literature frequency ($N = 156$ included sources).

Threat	Studies Reporting	Corpus Share
Prompt Injection	83	53.2%
Data Leakage	71	45.5%
Agent Hijacking	44	28.2%
RAG Poisoning	24	15.4%
Autonomous Tool Abuse	18	11.5%

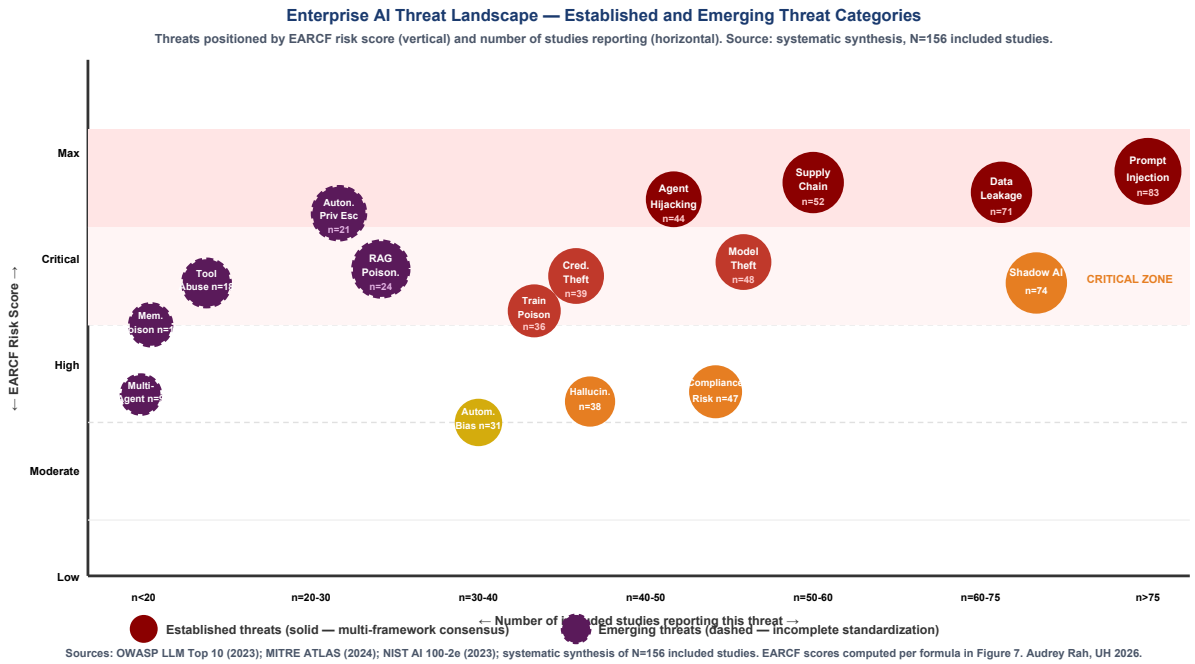


Figure 8: Enterprise AI threat landscape showing established and emerging threats.

Figure 8 presents the resulting threat landscape and summarizes the relationship among identified threat classes. (11; 12; 10) Prompt Injection was reported in 83 sources (53.2%), Data Leakage in 71 (45.5%), and Agent Hijacking in 44 (28.2%).

Five primary threat domains emerged: (80; 25)

1. Cybersecurity Threats
2. Privacy Threats
3. Governance Threats
4. Safety Threats
5. Enterprise Operational Threats

Although Prompt Injection was the most frequently cited vulnerability (83 sources; 53.2%), evidence suggests that Agent Hijacking (44 sources; 28.2%), Autonomous Tool Abuse (18 sources; 11.5%), and Multi-Agent Compromise (9 sources; 5.8%) represent the highest-impact threats because they can directly influence organizational systems, workflows, and decision-making processes. (12; 10; 81; 20; 21; 17) The review further indicates a shift from traditional model-centric threats toward agent-centric risks. (20; 82; 83) Earlier studies focused primarily on hallucination, model bias, and training-data exposure, whereas more recent publications emphasize excessive agency, autonomous decision making, memory poisoning, and tool misuse. (80; 25; 10; 22)

4.4 RQ3: Governance Framework Coverage and Control Mapping

U.S. and International Regulatory Landscape for Enterprise AI (2023–2026)

Mapped by applicability to enterprise AI deployment | Enforcement authority | Compliance obligation | Data: NIST (2023); CISA (2024); EU Parliament (2024); GAO (2024)

Regulation / Framework	Jurisdiction & Enforcer	Enterprise AI Scope	Obligation Type	Effective
EO 14110 — Safe, Secure, Trustworthy AI Federal Register 88 FR 75191 (2023)	U.S. Federal · OSTP	High-capability AI	Policy directive	Oct 2023
NIST AI RMF 1.0 (AI 100-1) NIST Special Publication · 2023	U.S. National · NIST	All enterprise AI	Voluntary framework	Jan 2023
HIPAA + AI Guidance (HHS OCR) 45 CFR Parts 160/164 + AI guidance 2024	U.S. Federal · HHS OCR	Healthcare AI	Mandatory / Civil penalty	Active
CCPA / CPRA (California) Cal. Civ. Code §1798.100 + AI provisions	California · CPPA	AI processing CA data	Mandatory	2020/2023
SEC AI Disclosure Rules Final rule: AI-related material risk disclosure	U.S. Federal · SEC	Public company AI	Mandatory / Disclosure	2023–2024
EU AI Act (Reg. 2024/1689) Official Journal EU L 2024/1689 · Extraterritorial	EU / extraterritorial · EAIB	U.S. firms with EU users	Mandatory / Fines	Aug 2026
ISO/IEC 42001:2023 — AI Management International standard · Certifiable	International · Self/3rd party	All enterprise AI	Voluntary / Certifiable	Dec 2023

Sources: U.S. Federal Register; NIST (2023a); EU Parliament (2024); ISO/IEC (2023); ISACA (2025); GAO (2024); HHS OCR (2024). Compliance obligations current as of April 2026. Audrey Rah, UH 2026.

Figure 9: U.S. and international regulatory landscape for enterprise AI.

Figure 9 summarizes the major regulatory and governance initiatives influencing enterprise AI deployment. (7; 84; 85; 23) The figure illustrates the increasing complexity of compliance obligations across jurisdictions. (84; 85; 86)

The review identified five governance frameworks that dominate enterprise AI governance practice: (7; 8; 10; 11; 72)

- NIST AI RMF
- ISO/IEC 42001
- OWASP LLM Top 10
- MITRE ATLAS
- COBIT

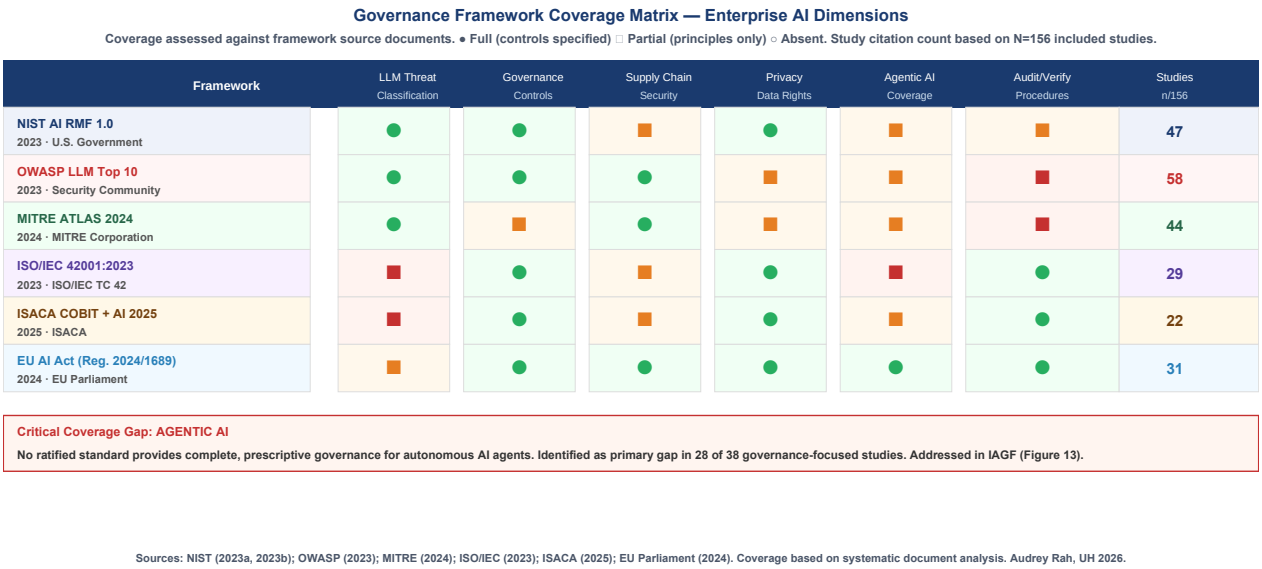


Figure 10: Governance framework coverage across enterprise AI risk dimensions.

Figure 10 compares the coverage provided by major governance frameworks across key enterprise AI dimensions and summarizes their relationship to major threat categories. (7; 10; 11; 22) The analysis highlights uneven coverage and identifies agentic AI governance as a recurring gap. (22; 10)

Each framework addresses a different governance objective: (7; 8; 10; 11; 72)

- NIST AI RMF focuses on AI risk management. (7)
- OWASP LLM Top 10 focuses on AI-specific security vulnerabilities. (10)
- MITRE ATLAS focuses on adversarial attack techniques. (11)
- ISO/IEC 42001 focuses on AI management systems and governance. (8)
- COBIT focuses on organizational accountability and oversight. (72)

The evidence demonstrates that no individual framework provides complete coverage of enterprise AI risks. (22; 7) Organizations therefore require a layered governance strategy integrating multiple frameworks. (22; 72)

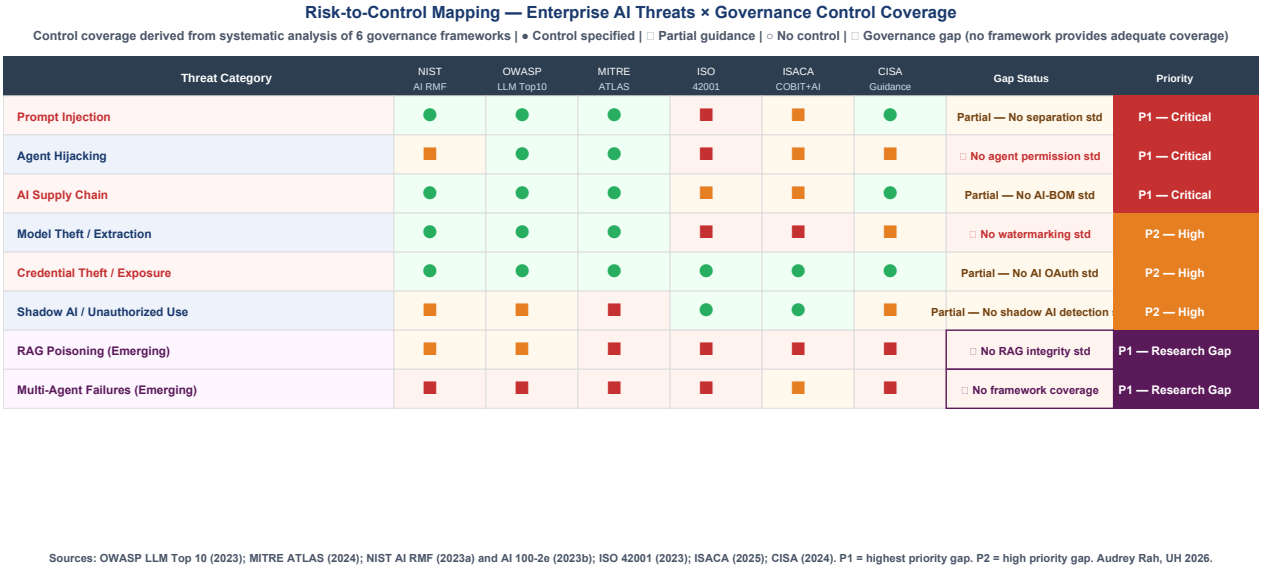


Figure 11: Risk-to-control mapping across enterprise AI governance frameworks.

Figure 11 maps major enterprise AI threats against governance framework coverage. Emerging threats such as RAG poisoning, agent hijacking, and multi-agent failures remain inadequately covered, highlighting high-priority control deficiencies and research gaps.

Figure 2 presents the governance-to-risk mapping derived from the synthesis process. (7; 8)

4.5 RQ4: Governance Gaps, Maturity, and Lifecycle Synthesis

Despite the increasing maturity of AI governance programs, significant gaps remain. (87; 22)

The most frequently reported governance gaps include: (22; 10; 36)

1. Multi-agent accountability
2. Memory-state auditing
3. Autonomous decision transparency
4. Tool authorization controls
5. RAG knowledge-source validation
6. AI-to-AI communication governance
7. Agent lifecycle management

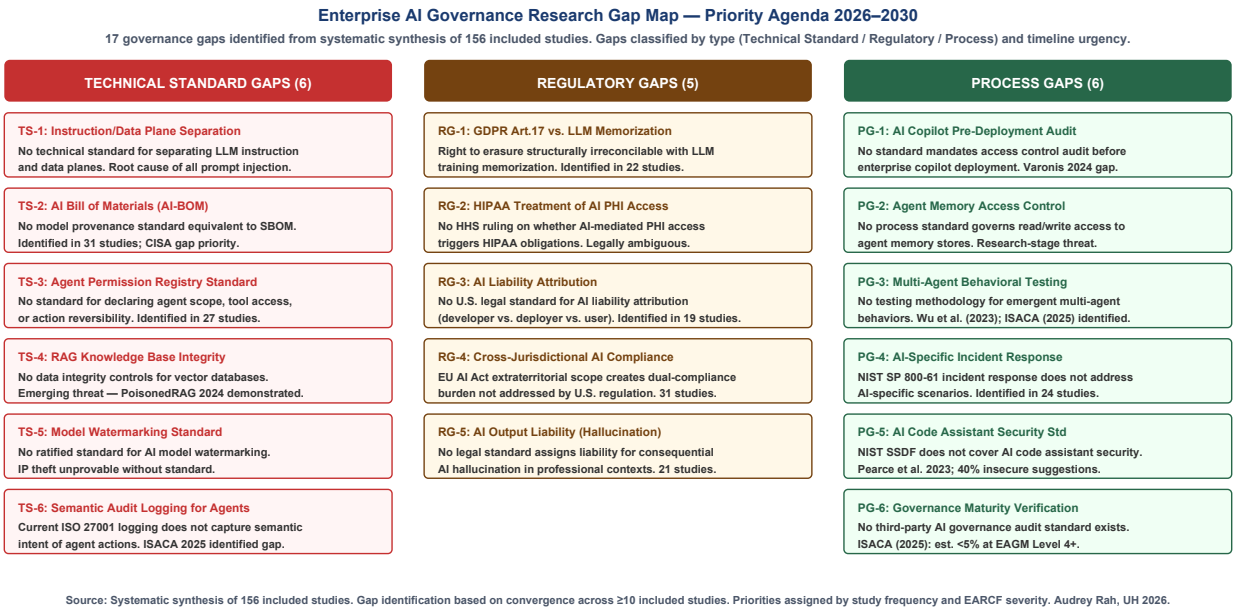


Figure 12: Enterprise AI governance research gap map and future research agenda.

Figure 12 summarizes seventeen major technical, regulatory, and process-related governance gaps identified through the review, demonstrating that governance development continues to lag behind enterprise AI adoption and representing priority areas for future research and standardization. (22)

The evidence suggests that governance frameworks have evolved more slowly than enterprise AI capabilities. (87; 1) While organizations increasingly deploy autonomous and semi-autonomous AI systems, many governance mechanisms remain focused on traditional machine-learning deployments. (17; 22)

This governance lag is particularly evident in emerging agentic AI ecosystems, where autonomous agents can access tools, retrieve organizational data, execute workflows, and interact with external services. (16; 17; 36)

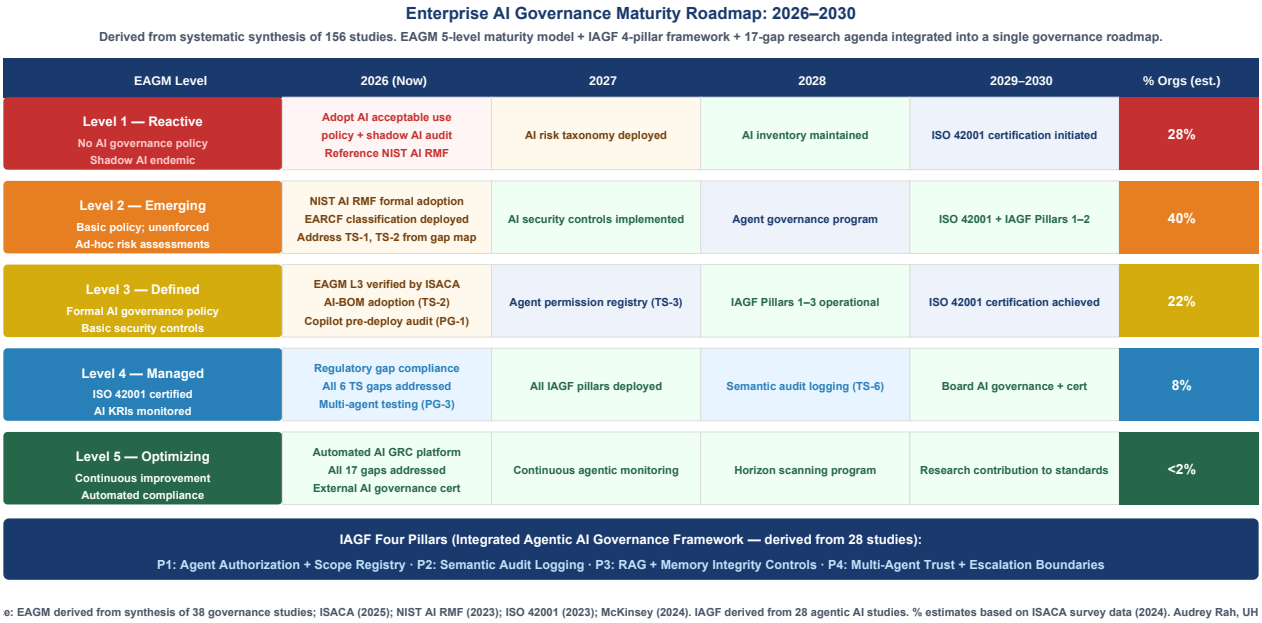


Figure 13: Enterprise AI Governance Maturity Roadmap (EAGM) and governance evolution path.

The maturity analysis suggests that most organizations currently operate within intermediate governance stages and have not yet achieved fully optimized, continuously monitored AI governance capabilities. Figure 13 presents the Enterprise AI Governance EAGM developed from the synthesized evidence and outlines the progression from reactive governance practices toward optimized and continuously monitored enterprise AI governance. (22; 72)

The majority of organizations currently operate between Level 2 and Level 3 maturity, characterized by basic AI policies, approved tool inventories, initial risk assessments, and limited monitoring capabilities. (87; 22)

Only a small subset of organizations demonstrated characteristics associated with Level 4 governance, including automated monitoring, enterprise-wide AI oversight, formal risk committees, and integrated compliance management. (22; 78)

Level 5 governance remains largely aspirational and is currently observed only in highly regulated sectors and among a small number of large technology organizations. (72; 88)

The synthesized evidence further supports the development of anEAGL derived from the governance, risk management, and continuous improvement principles identified across NIST AI RMF, COBIT, ISO/IEC 42001, and related enterprise governance literature. (7; 72; 8)

The proposed lifecycle consists of seven iterative phases: (7; 72)

1. Discovery and Classification
2. Evidence-Based Risk Assessment
3. Governance Policy Design
4. Controlled Deployment
5. Continuous Monitoring
6. Incident Response
7. Governance Review and Update

The lifecycle model addresses the governance lag problem identified throughout the review by treating governance as a continuous organizational capability rather than a one-time deployment activity. (7; 22) The proposed lifecycle is not intended to replace existing governance frameworks; rather, it provides a synthesized operational process that integrates governance, risk management, monitoring, and continuous improvement activities across the enterprise AI system lifecycle. (7; 8; 72)

4.6 Summary of Findings

Four major findings emerged from the review. (29; 31)

First, enterprise AI adoption has expanded rapidly across all major sectors, with enterprise copilots and cloud-integrated AI services demonstrating the highest adoption rates. (1; 4; 5)

Second, AI security risks are increasingly shifting from model-centric vulnerabilities toward agent-centric threats involving autonomous behavior, tool access, memory persistence, and workflow execution. (20; 10; 11)

Third, existing governance frameworks provide complementary coverage rather than comprehensive protection, requiring organizations to integrate multiple standards and control frameworks. (7; 8; 10; 11; 72)

Fourth, governance maturity continues to lag behind technological capability, creating a widening gap between enterprise AI deployment and organizational oversight. (87; 22)

These findings collectively support the need for integrated governance architectures capable of addressing both current generative AI deployments and future agentic AI ecosystems. (34; 36; 24)

5 Conclusion

This PRISMA-compliant systematic review synthesized 156 included sources on enterprise generative AI adoption, security risks, and governance in United States organizations. (29; 30; 31) The evidence base comprised peer-reviewed literature (50%), industry reports (22%), standards (15%), and government publications (13%), triangulated to address four predefined research questions on platform taxonomy, threat exposure, framework coverage, and governance maturity. (76; 31)

Three empirical patterns dominated the synthesis. First, enterprise AI adoption is concentrated in productivity-integrated platforms rather than standalone tools: commercial LLM services, enterprise copilots, and cloud AI platforms showed the highest deployment evidence density in the extraction matrix (46.2%, 37.2%, and 34.6% of included sources, respectively). (1; 4; 5; 6) Second, the enterprise threat landscape is shifting from model-centric to agent-centric exposure. Although 65 distinct threat categories were identified, prompt injection (83 sources; 53.2%), data leakage (71; 45.5%), and agent hijacking (44; 28.2%) were the most frequently documented risks, while autonomous tool abuse, RAG poisoning, and multi-agent failures remain comparatively under-governed. (12; 15; 10; 20; 17) Third, dominant governance frameworks—NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, MITRE ATLAS, and COBIT—provide complementary rather than comprehensive coverage; most organizations remain at intermediate governance maturity, creating a measurable lag between deployment capability and oversight. (7; 8; 10; 11; 72; 87; 22)

To translate these findings into actionable structure, the review contributes five author-derived synthesis instruments grounded in the extracted evidence: theEAPT, the CAS, the EARCF, the Enterprise AI Governance EAGM, and theEAGL. (32; 7; 8; 72; 22) Together, they support platform classification, comparative adoption assessment, risk prioritization, maturity benchmarking, and continuous lifecycle governance for generative and agentic AI deployments.

Future research should empirically validate CAS and EARCF through large-scale organizational studies, develop standardized instruments for agent memory auditing and multi-agent accountability, and evaluate zero-trust control architectures in operational agentic environments. (30; 75; 17; 36) As enterprise AI becomes embedded infrastructure, governance maturity—not model capability alone—will determine whether organizations can capture productivity benefits while maintaining security, compliance, and organizational trust. (7; 8; 85; 34)

Detailed search strings, screening records, quality-assessment rubrics, CAS/EARCF scoring tables, extended governance-gap inventory, and supporting figures are provided in Appendices A–E.

Acknowledgments

The author would like to thank the University Information Technology (UIT) department at the University of Houston for its support. Special thanks to Mr. Sven, Assistant Vice President and Vice Chancellor for IT Security and Chief Information Security Officer (CISO), for sharing his professional insights and experience in cybersecurity, governance, and risk management.

A Database Search Strings

A.1 Complete Search Protocol and Database Queries

This appendix provides the reproducibility record for the systematic search described in Section 3 of the main manuscript. The search window covered January 2018 through April 2026. Boolean operators and database-specific syntax were applied where supported. Deduplication was performed before title-and-abstract screening. Query logs were archived for auditability (29; 30).

A.2 Academic and Grey-Literature Sources

The review searched seven academic databases and authoritative grey-literature repositories: Scopus, Web of Science, IEEE Xplore, ACM Digital Library, SpringerLink, ScienceDirect, Google Scholar, NIST, CISA, NSA, ISACA, OWASP, MITRE ATLAS, ISO documentation, Stanford HAI, Gartner, McKinsey, and IBM Institute for Business Value (7; 74; 10; 11; 2; 1).

A.3 Database Search Queries

Table 7: Search queries executed across academic and grey-literature sources.

Database	Executed Search Query	Field Scope
Scopus	`TITLE-ABS-KEY(("Generative AI" OR "Large Language Model" OR "Foundation Model" OR "Enterprise AI") AND (Security OR Governance OR Risk OR Threat OR Compliance) AND (Enterprise OR Organization OR Corporate OR "United States"))`	Title, Abstract, Keywords
Web of Science	`TS=(("Generative AI" OR "LLM" OR "Large Language Model" OR "GPT" OR "ChatGPT") AND (Cybersecurity OR "AI Governance" OR "AI Risk" OR "Enterprise Risk"))`	Topic
IEEE Xplore	`("Generative AI" OR "Large Language Model" OR "Foundation Model") AND (Security OR "Prompt Injection" OR "AI Governance" OR "Enterprise Deployment")`	Full metadata
ACM Digital Library	`[[All: "generative ai"] OR [All: "large language model"] OR [All: "foundation model"]] AND [[All: security] OR [All: governance] OR [All: risk] OR [All: "enterprise ai"]]`	All fields
SpringerLink	`("Generative AI" OR "Large Language Model") AND (Cybersecurity OR "AI Governance" OR "Enterprise Risk" OR "AI Safety")`	Full text
ScienceDirect	`TITLE-ABSTR-KEY("Generative AI" OR "Large Language Model" OR "Enterprise AI") AND TITLE-ABSTR-KEY(Security OR Governance OR Risk OR Compliance)`	Title, Abstract, Keywords
Google Scholar	`"generative AI" OR "large language model" enterprise security governance risk 2018..2026`	Full-text index

Database	Executed Search Query	Field Scope
Grey literature	Manual search using `"AI risk" OR "AI governance" OR "generative AI" OR "LLM security" OR "enterprise AI"` across NIST, CISA, ISACA, OWASP, MITRE ATLAS, Stanford HAI, McKinsey, Gartner, and IBM IBV sources	Site search

A.4 Targeted Supplemental Searches

Additional searches were conducted for prompt injection, RAG poisoning, excessive agency, model extraction, AI software supply chain, AI TRiSM, zero-trust AI controls, multi-agent accountability, and memory-state auditing (12; 15; 14; 10; 35; 17; 20).

B Screening Records and PRISMA Audit Trail

B.1 Inclusion and Exclusion Criteria

Table 8: Inclusion and exclusion criteria applied during screening.

Criterion	Inclusion Rule	Exclusion Rule
Topic relevance	Enterprise AI deployment, governance, cybersecurity, risk management, platform adoption, or agentic AI risk	Consumer-only AI, purely theoretical AI without enterprise application, or non-AI studies
Publication date	January 2018–April 2026	Before January 2018, except foundational methodology or governance references
Language	English-language publications	Non-English publications without reliable translation
Source type	Peer-reviewed studies, standards, government publications, and authoritative industry reports	Blog posts, vendor marketing pages, opinion pieces, or grey literature without institutional provenance
Geographic scope	United States enterprise context or internationally applicable enterprise AI findings	Non-enterprise consumer studies with no transferable organizational relevance
Quality threshold	Quality score $\geq 6.0/10.0$	Quality score $< 6.0/10.0$

B.2 PRISMA Screening Summary

Table 9: PRISMA-style screening summary.

Review Stage	Number of Records
Records identified	4,852
Duplicates removed	866
Records screened after deduplication	3,986
Records excluded during title and abstract screening	3,249
Full-text records assessed	737
Full-text records excluded for scope mismatch	174
Full-text records excluded for quality score < 6.0	407
Sources included in final synthesis	156

Of the 156 included sources, 94 sources met the high-quality designation with scores of 7.0 or higher, and 62 sources met the acceptable-quality threshold with scores between 6.0 and 6.9. Full-text exclusion categories were treated as mutually exclusive; therefore, $737 - 581 = 156$.

B.3 Full-Text Exclusion Definitions

- Scope mismatch: The source addressed AI generally but lacked enterprise deployment, governance, cybersecurity, or transferable organizational relevance.
- Quality below threshold: The source scored below 6.0 on the QA1–QA4 rubric.

C Quality Assessment, Evidence Hierarchy, and Extraction

C.1 Quality Assessment Rubric

Table 10: Quality assessment rubric applied to retrieved sources.

Criterion	Score Range	Assessment Focus
QA1: Methodological rigor	0–2.5	Clarity of research design, transparency of data collection, reproducibility of methods, peer-review status, or formal standards-development process
QA2: Evidence quality	0–2.5	Strength of empirical support, documented incidents, validated frameworks, experimental results, or formally established control guidance
QA3: Citation or institutional impact	0–2.5	Citation impact for academic studies or adoption and recognition across standards, government, or professional practice sources
QA4: Enterprise AI relevance	0–2.5	Direct applicability to enterprise AI deployment, cybersecurity, governance, risk management, platform adoption, or organizational control design

C.2 Operational Scoring Bands

- QA1: 2.0–2.5 indicates peer-reviewed work or a formal standard with documented methodology; 1.0–1.9 indicates limited methodological description; 0–0.9 indicates no methodological

description.

- QA2: 2.0–2.5 indicates primary empirical or incident evidence; 1.0–1.9 indicates secondary or framework-only evidence; 0–0.9 indicates unsupported claims.
- QA3: 2.0–2.5 indicates high citation or institutional impact; 1.0–1.9 indicates moderate impact; 0–0.9 indicates limited impact.
- QA4: 2.0–2.5 indicates direct enterprise AI relevance; 1.0–1.9 indicates adjacent but transferable relevance; 0–0.9 indicates limited enterprise relevance.

Quality scoring was performed by the primary reviewer using a pre-specified rubric. The single-reviewer scoring process is acknowledged as a methodological limitation (29; 30).

C.3 Evidence Hierarchy

Table 11: Evidence hierarchy used during synthesis.

Evidence Type	Primary Use in Review	Examples
Peer-reviewed literature	Scientific findings, attack mechanisms, model behavior, benchmarks, and research gaps	LLM security studies, agentic AI papers, RAG studies
Standards and frameworks	Governance controls, risk-management functions, assurance requirements, and security mappings	NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, MITRE ATLAS
Government publications	Regulatory direction, national cybersecurity priorities, public-sector AI security guidance	CISA, NSA, NIST, EU AI Act documentation
Industry reports	Adoption trends, enterprise deployment patterns, market structure, practitioner concerns	McKinsey, Gartner, IBM IBV, Stanford HAI AI Index

C.4 Evidence Extraction and Coding Fields

For each included source, the following fields were extracted: source type, publication year, platform category, enterprise relevance, adoption evidence, security risk category, governance framework reference, control mechanism, and mapping to RQ1–RQ4 (31; 76). Extraction followed a concept-centric synthesis approach rather than a purely chronological narrative structure (31).

D CAS and EARCF Detailed Scoring Methodology

D.1 Composite Adoption Score

The Composite Adoption Score is defined in the main manuscript as:

$$\text{CAS} = \frac{\text{Enterprise Penetration} + \text{Market Share Index} + \text{Active User Volume} + \text{Analyst Tier Rating}}{4}$$

Equal weighting follows the use of transparent equal-weighted composite models when evidence does not justify differential weighting (32). Tier assignments were defined as Tier 1 for CAS values of 8.0 or higher, Tier 2 for values from 6.0 to 7.9, and Tier 3 for values from 4.0 to 5.9. Sensitivity analysis

using weight perturbations of ±0.10 did not change the Tier 1 classifications reported in the main manuscript.

Table 12: CAS dimension scoring rubric.

Score	Enterprise Penetration	Market Share Index	Active User Volume	Analyst Tier Rating
9–10	More than 70% deployed	Category leader	More than 1M enterprise seats	Gartner Leader and Forrester Leader
7–8	50–70% deployed	Top-three share	500K–1M seats	Gartner or Forrester Leader
5–6	30–50% deployed	Moderate share	100K–499K seats	Challenger or Strong Performer
3–4	10–29% deployed	Low share	10K–99K seats	Visionary or Niche
1–2	Less than 10% deployed	Minimal share	Less than 10K seats	Not independently ranked

D.2 Enterprise AI Risk Classification Framework

The Enterprise AI Risk Classification Framework is defined in the main manuscript as:

$$\text{EARCF} = (0.30 \times \text{Impact}) + (0.25 \times \text{Exposure}) + (0.25 \times \text{Autonomy}) + (0.20 \times \text{Data Sensitivity})$$

Risk tiers were defined as Critical for scores of 4.0 or higher, High for scores from 3.0 to 3.9, Moderate for scores from 2.0 to 2.9, and Low for scores below 2.0. The scoring dimensions align with recurring risk concepts across NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, MITRE ATLAS, NIST SP 800-53, and ISO/IEC 27001 (7; 8; 10; 11; 33; 64).

Table 13: EARCF dimension scoring rubric.

Score	Impact	Exposure	Autonomy	Data Sensitivity
5	Catastrophic harm	Internet-facing or broad API access	Full autonomous execution	PHI, PII, financial, or legal data
4	Major breach or disruption	Broad enterprise access	Multi-step agent execution	Sensitive regulated data
3	Moderate disruption	Internal authenticated access	Pre-approved sequences with logging	Business-sensitive internal data
2	Minor disruption	Restricted users	Human-approved steps	Non-sensitive internal data
1	Negligible impact	Air-gapped or advisory only	No autonomous action	Public or anonymized data

E Extended Governance Mappings and Gap Inventory

E.1 Governance Coverage Coding Procedure

Governance coverage in the framework comparison and risk-control mapping was coded using the following interpretation:

- Full coverage: The framework provides specific and implementable controls with identifiable clauses, functions, or technique categories.
- Partial coverage: The framework provides principles-level guidance but does not define complete implementation controls.
- No coverage: The framework does not directly address the dimension or threat.
- Priority gap: No assessed framework provides adequate coverage for a high-impact or emerging enterprise AI risk.

Framework sources included NIST AI RMF, ISO/IEC 42001, OWASP LLM Top 10, MITRE ATLAS, COBIT, ISACA guidance, and CISA guidance (7; 8; 10; 11; 72; 22; 23).

E.2 Extended Governance Gap Inventory

Table 14: Extended governance gap inventory.

No.	Gap	Category	Priority	Representative Evidence
1	Multi-agent accountability	Process	P1	ISACA (22); AutoGen (17)
2	Memory-state auditing	Technical	P1	OWASP (10); NIST AI RMF (7)
3	Autonomous decision transparency	Process	P1	ISACA (22); Liu et al. (20)
4	Tool authorization controls	Technical	P1	OWASP (10); CISA (36)
5	RAG knowledge-source validation	Technical	P1	PoisonedRAG (15); Greshake et al. (12)
6	AI-to-AI communication governance	Process	P2	Wu et al. (17)
7	Agent lifecycle management	Process	P2	MITRE ATLAS (11)
8	RAG corpus poisoning controls	Technical	P1	Zou et al. (15)
9	Multi-agent failure containment	Technical	P1	Liu et al. (20)
10	Persistent agent memory governance	Technical	P1	OWASP (10)
11	Cross-jurisdictional AI compliance harmonization	Regulatory	P2	EU AI Act (84); NIST AI RMF (7)
12	AI software supply-chain attestation	Technical	P2	NIST SSDF (35)
13	Enterprise copilot data-boundary enforcement	Process	P2	Microsoft Copilot documentation (6)
14	Developer-AI secure-code assurance	Process	P2	Pearce et al. (79)
15	Sector-specific AI incident reporting	Regulatory	P2	SEC (86); HHS OCR (88)
16	Continuous AI control validation	Process	P2	COBIT (72)
17	Zero-trust enforcement for AI-mediated actions	Technical	P1	NSA and CISA (24; 36)

F Traceability and Reproducibility Records

F.1 Source-Type Classification

Table 15 reports the mutually exclusive primary source-type classification applied during evidence extraction. Each of the 156 included sources was assigned exactly one primary type for synthesis reporting. These counts correspond to Table 5 in the main manuscript Results section and differ from binary academic-versus-grey counts sometimes shown in PRISMA workflow annotations.

Table 15: Primary source-type classification of included sources ($N = 156$).

Source Type	Count	Percentage
Peer-reviewed literature	78	50%
Standards and frameworks	24	15%
Government publications	21	13%
Industry reports	33	22%
Total	**156**	**100%**

F.2 Source-to-Figure Traceability Matrix

Table 16: Source-to-figure traceability matrix.

Figure	Purpose	Primary Sources	Instrument	RQ
1	PRISMA workflow	Page et al. (29)	PRISMA 2020	All
2	Enterprise AI Platform Taxonomy	McKinsey, Gartner, Stanford HAI	EAPT and CAS	RQ1
3	Functional architecture	NIST, OWASP, MITRE	EARCF	RQ1, RQ2
4	Adoption trend	McKinsey, Stanford HAI, Gartner, IBM IBV	Adoption analysis	RQ1
5	Framework coverage	NIST, ISO, OWASP, MITRE	Governance mapping	RQ3
6	Threat landscape	OWASP, MITRE, Greshake, Liu	EARCF	RQ2
7	EARCF model	NIST, ISO, OWASP, ISACA	EARCF	RQ2, RQ3
8	CAS ranking	McKinsey, Gartner, Dawes	CAS	RQ1
9	Regulatory landscape	NIST, EU AI Act, OECD	Regulatory synthesis	RQ3
10	Sector heat map	McKinsey, IBM IBV, Gartner	EARCF	RQ1, RQ3
11	Risk-to-control map	OWASP, MITRE, NIST, ISACA	Governance mapping	RQ2, RQ3
12	Governance gap map	ISACA, CISA, NIST	Gap synthesis	RQ4
13	EAGM roadmap	ISACA, NIST, ISO, McKinsey	EAGM and EAGL	RQ4

G Supplementary Materials

The following supplementary files support independent replication of this review: S1, machine-readable search export logs; S2, screening decision records; S3, blank evidence extraction template; S4, platform-level CAS and EARCF worksheets; and S5, full governance framework crosswalk tables. These materials support reproducibility and are available from the corresponding author upon reasonable request (29; 30).

References

[1] McKinsey & Company. *The State of AI in Early 2024: Gen AI Adoption Spikes and Starts to Generate Value*. 2024. https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai

[2] Stanford Human-Centered AI Institute. *AI Index Report 2024*. 2024. https://aiindex.stanford.edu/report/

[3] IBM Institute for Business Value. *AI in Action: IBM Global AI Adoption Index 2024*. 2024. https://www.ibm.com/thought-leadership/institute-business-value/report/ai-adoption-index

[4] Gartner Inc.. *Magic Quadrant for Cloud AI Developer Services*. 2024. https://www.gartner.com/en/documents/magic-quadrant-cloud-ai-developer-services

[5] Forrester Research. *The State of Generative AI in the Enterprise, 2024*. 2024. https://www.forrester.com/report/the-state-of-generative-ai-in-the-enterprise-2024/RES181411

[6] Microsoft Corporation. *Microsoft Copilot for Microsoft 365: Security, Privacy, and Compliance*. 2024. https://www.microsoft.com/en-us/trust-center/product-overview/microsoft-copilot

[7] National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST, NIST AI 100-1, 2023. https://doi.org/10.6028/NIST.AI.100-1

[8] ISO/IEC. *ISO/IEC 42001:2023 — Information Technology — Artificial Intelligence — Management System*. International Organization for Standardization, 2023. https://www.iso.org/standard/81230.html

[9] National Institute of Standards and Technology. *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*. NIST, NIST AI 100-2e2023, 2023. https://doi.org/10.6028/NIST.AI.100-2e2023

[10] OWASP Foundation. *OWASP Top 10 for Large Language Model Applications, Version 1.1*. 2023. https://owasp.org/www-project-top-10-for-large-language-model-applications/

[11] MITRE Corporation. *MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*. 2024. https://atlas.mitre.org/

[12] Greshake, K. and Abdelnabi, S. and Mishra, S. and Endres, C. and Holz, T. and Fritz, M. *Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injections*. In *Proceedings of the ACM Workshop on Artificial Intelligence and Security (AISec)*, 2023. https://arxiv.org/abs/2302.12173

[13] Zou, A. and Wang, Z. and Kolter, J. Z. and Fredrikson, M. *Universal and Transferable Adversarial Attacks on Aligned Language Models*. arXiv preprint arXiv:2307.15043, 2023. https://arxiv.org/abs/2307.15043

[14] Carlini, N. and Tramer, F. and Wallace, E. and Jagielski, M. and Herbert-Voss, A. and Lee, K. and Roberts, A. and Brown, T. and Song, D. and Erlingsson, U. and Oprea, A. and Raffel, C. *Extracting Training Data from Large Language Models*. In *Proceedings of the 30th USENIX Security Symposium*, pp. 2633–2650, 2021. https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting

[15] Zou, W. and Geng, R. and Wang, B. and Guo, J. *PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation of Large Language Models*. arXiv preprint arXiv:2402.07867, 2024. https://arxiv.org/abs/2402.07867

[16] Yao, S. and Zhao, J. and Yu, D. and Du, N. and Shafran, I. and Narasimhan, K. and Cao, Y. *ReAct: Synergizing Reasoning and Acting in Language Models*. In *Proceedings of the 11th International Conference on Learning Representations (ICLR)*, 2023. https://openreview.net/forum?id=WE_vluYUL-X

[17] Wu, Q. and Bansal, G. and Zhang, J. and Wu, Y. and Zhang, S. and Zhu, E. and Li, B. and Jiang, L. and Zhang, X. and Wang, C. *AutoGen: Enabling Next-Gen LLM Applications via Multi-Agent Conversation Framework*. arXiv preprint arXiv:2308.08155, 2023. https://arxiv.org/abs/2308.08155

[18] Wang, G. and Xie, Y. and Jiang, Y. and Mandlekar, A. and Zhu, C. and Fan, L. and Anandkumar, A. *Voyager: An Open-Ended Embodied Agent with Large Language Models*. arXiv preprint arXiv:2305.16291, 2023. https://arxiv.org/abs/2305.16291

[19] Hong, S. and Zheng, X. and Chen, J. and Cheng, Y. and Wang, J. and Zhang, C. and Wang, Z. and Yau, S. K. S. and Lin, Z. and Zhou, L. and others. *MetaGPT: Meta Programming for Multi-Agent Collaborative Framework*. arXiv preprint arXiv:2308.00352, 2023. https://arxiv.org/abs/2308.00352

[20] Liu, V. and Kamoi, R. and Ito, S. and Zhang, Q. and Greshake, K. and Wu, T. and Russ, C. and Liu, Y. and Zhang, H. and Zhou, P. *Automatic and Universal Prompt Injection Attacks Against LLM Agents*. arXiv preprint arXiv:2403.04957, 2024. https://arxiv.org/abs/2403.04957

[21] Ruan, S. and Yang, C. and Desai, S. and Qiao, S. and Gray, A. and Li, B. and Su, D. and Yu, B. and Li, B. and Jiang, L. and others. *Identifying the Risks of LM Agents with an LM-Emulated Sandbox*. arXiv preprint arXiv:2309.15817, 2023. https://arxiv.org/abs/2309.15817

[22] ISACA. *Leveraging COBIT for Effective AI System Governance*. 2025. https://www.isaca.org/resources/whitepapers/leveraging-cobit-for-effective-ai-system-governance

[23] Cybersecurity and Infrastructure Security Agency. *CISA Roadmap for Artificial Intelligence*. 2024. https://www.cisa.gov/ai

[24] National Security Agency. *Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems*. 2024. https://media.defense.gov/2024/Apr/15/2003439257/-1/-1/0/CSI-DEPLOYING-AI-SYSTEMS-SECURELY.PDF

[25] Bommasani, R. and Hudson, D. A. and Adeli, E. and Altman, R. and Arora, S. and von Arx, S. and Bernstein, M. S. and Bohg, J. and Bosselut, A. and Brunskill, E. and others. *On the Opportunities and Risks of Foundation Models*. arXiv preprint arXiv:2108.07258, 2021. https://arxiv.org/abs/2108.07258

[26] Raji, T. D. and Smart, A. and White, R. N. and Mitchell, M. and Gebru, T. and Hutchinson, B. and Smith-Loud, J. and Theron, D. and Barnes, P. *Closing the AI Accountability Gap: Defining an End-to-End Framework for Internal Algorithmic Auditing*. In *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency*, pp. 33–44, 2020. https://doi.org/10.1145/3351095.3372873

[27] Mitchell, M. and Wu, S. and Zaldivar, A. and Barnes, P. and Vasserman, L. and Hutchinson, B. and Spitzer, E. and Raji, T. D. and Gebru, T. *Model Cards for Model Reporting*. In *Proceedings of the 2019 Conference on Fairness, Accountability, and Transparency*, pp. 220–229, 2019. https://doi.org/10.1145/3287560.3287596

[28] IBM Security. *Cost of a Data Breach Report 2024*. 2024. https://www.ibm.com/reports/data-breach

[29] Page, M. J. and McKenzie, J. E. and Bossuyt, P. M. and Boutron, I. and Hoffmann, T. C. and Mulrow, C. D. and Shamseer, L. and Tetzlaff, J. M. and Akl, E. A. and Brennan, S. E. and Chou, R. and Glanville, J. and Grimshaw, J. M. and Hróbjartsson, A. and Lalu, M. M. and Li, T. and Loder, E. W. and Mayo-Wilson, E. and McDonald, S. and McGuinness, L. A. and Stewart, L. A. and Thomas, J. and Tricco, A. C. and Welch, V. A. and Whiting, P. and Moher, D. *The PRISMA 2020 statement: An updated guideline for reporting systematic reviews*. BMJ, 372:n71, 2021. https://doi.org/10.1136/bmj.n71

[30] Kitchenham, B. and Charters, S. *Guidelines for Performing Systematic Literature Reviews in Software Engineering*. Keele University and Durham University, EBSE-2007-01, 2007. https://www.elsevier.com/__data/promis_misc/525444systematicreviewsguide.pdf

[31] Webster, J. and Watson, R. T. *Analyzing the past to prepare for the future: Writing a literature review*. MIS Quarterly, 26(2):xiii–xxiii, 2002. https://www.jstor.org/stable/4132319

[32] Dawes, R. M. *The robust beauty of improper linear models in decision making*. American Psychologist, 34(7):571–582, 1979. https://doi.org/10.1037/0003-066X.34.7.571

[33] National Institute of Standards and Technology. *Security and Privacy Controls for Information Systems and Organizations*. NIST, NIST SP 800-53 Rev. 5, 2020. https://doi.org/10.6028/NIST.SP.800-53r5

[34] National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST, NIST CSWP 29, 2024. https://doi.org/10.6028/NIST.CSWP.29

[35] National Institute of Standards and Technology. *Secure Software Development Practices for Generative AI and Dual-Use Foundation Models (NIST SP 800-218A)*. NIST, NIST SP 800-218A, 2024. https://csrc.nist.gov/pubs/sp/800/218/a/final

[36] Cybersecurity and Infrastructure Security Agency and National Security Agency and Federal Bureau of Investigation and NCSC-UK. *Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems*. 2024. https://www.cisa.gov/resources-tools/resources/deploying-ai-systems-securely

[37] Brown, T. and Mann, B. and Ryder, N. and Subbiah, M. and Kaplan, J. D. and Dhariwal, P. and Neelakantan, A. and Shyam, P. and Sastry, G. and Askell, A. and others. *Language Models are Few-Shot Learners*. In *Advances in Neural Information Processing Systems 33*, pp. 1877–1901, 2020. https://proceedings.neurips.cc/paper/2020/hash/1457c0d6bfcb4967418bfb8ac142f64a-Abstract.html

[38] OpenAI. *GPT-4 System Card*. 2023. https://cdn.openai.com/papers/gpt-4-system-card.pdf

[39] Touvron, H. and Lavril, T. and Izacard, G. and Martinet, X. and Lachaux, M. A. and Lacroix, T. and Rozière, B. and Goyal, N. and Hambro, E. and Azhar, F. and others. *LLaMA: Open and Efficient Foundation Language Models*. arXiv preprint arXiv:2302.13971, 2023. https://arxiv.org/abs/2302.13971

[40] Google Gemini Team. *Gemini: A Family of Highly Capable Multimodal Models*. arXiv preprint arXiv:2312.11805, 2024. https://arxiv.org/abs/2312.11805

[41] Rah, A. *Agentic and Multi-agent Systems: A Systematic Review of Tool Use, Benchmarks, and Governance*. Research Square Preprint, Version 1, 2026. https://doi.org/10.21203/rs.3.rs-9839978/v1

[42] Debenedetti, E. and Zhang, J. and Balunovic, M. and Beutel, A. and Chen, L. and Jia, R. *AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents*. arXiv preprint arXiv:2406.01644, 2024. https://arxiv.org/abs/2406.01644

[43] Vaswani, A. and Shazeer, N. and Parmar, N. and Uszkoreit, J. and Jones, L. and Gomez, A. N. and Kaiser, L. and Polosukhin, I. *Attention Is All You Need*. In *Advances in Neural Information Processing Systems 30*, pp. 5998–6008, 2017. https://proceedings.neurips.cc/paper/2017/hash/3f5ee243547dee91fbd053c1c4a845aa-Abstract.html

[44] Devlin, J. and Chang, M. W. and Lee, K. and Toutanova, K. *BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding*. In *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics*, pp. 4171–4186, 2019. https://aclanthology.org/N19-1423/

[45] Radford, A. and Wu, J. and Child, R. and Luan, D. and Amodei, D. and Sutskever, I. *Language Models are Unsupervised Multitask Learners*. 2019. https://cdn.openai.com/better-language-models/language_models_are_unsupervised_multitask_learners.pdf

[46] Wei, J. and Tay, Y. and Bommasani, R. and Raffel, C. and Zoph, B. and Borgeaud, S. and Yogatama, D. and Bosma, M. and Zhou, D. and Metzler, D. and Chi, E. H. and Hashimoto, T. and Vinyals, O. and Liang, P. and Dean, J. and Fedus, W. *Emergent Abilities of Large Language Models*. Transactions on Machine Learning Research, 2022. https://arxiv.org/abs/2206.07682

[47] Ouyang, S. and Li, B. and Song, D. *BadChain: Backdoor Chain-of-Thought Prompting for Large Language Models*. arXiv preprint arXiv:2401.12242, 2023. https://arxiv.org/abs/2401.12242

[48] Jobin, A. and Ienca, M. and Vayena, E. *The Global Landscape of AI Ethics Guidelines*. Nature Machine Intelligence, 1(9):389–399, 2019. https://doi.org/10.1038/s42256-019-0088-2

[49] McKinsey & Company. *The State of AI in 2022—and a Half Decade in Review*. 2022. https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai

[50] McKinsey & Company. *The State of AI in 2023: Generative AI's Breakout Year*. 2023. https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai

[51] OpenAI. *GPT-4 Technical Report*. 2024. https://openai.com/research/gpt-4

[52] Anthropic. *Claude Model Card and Evaluations*. 2024. https://www.anthropic.com/claude

[53] Liang, P. and others. *Holistic Evaluation of Language Models*. arXiv preprint arXiv:2211.09110, 2022. https://arxiv.org/abs/2211.09110

[54] Chao, P. and Robey, A. and Dobriban, E. and Hassani, H. and Pappas, G. J. and Wong, E. *Jailbreaking Black Box Large Language Models in Twenty Queries*. arXiv preprint arXiv:2310.08419, 2023. https://arxiv.org/abs/2310.08419

[55] Zou, A. and Wang, Z. and Carlini, N. and Nasr, M. and Kolter, J. Z. and Fredrikson, M. *Universal and Transferable Adversarial Attacks on Aligned Language Models*. arXiv preprint arXiv:2307.15043, 2023. https://arxiv.org/abs/2307.15043

[56] Liu, X. and Gong, N. Z. and Wang, Q. and Li, B. *AutoDAN: Generating Stealthy Jailbreak Prompts on Aligned Large Language Models*. arXiv preprint arXiv:2310.04451, 2023. https://arxiv.org/abs/2310.04451

[57] Yu, J. and Lin, X. and Yu, Z. and Xing, X. *GPTFUZZER: Red Teaming Large Language Models with Auto-Generated Jailbreak Prompts*. arXiv preprint arXiv:2309.01454, 2023. https://arxiv.org/abs/2309.01454

[58] Nasr, M. and Carlini, N. and Hayase, J. and Jagielski, M. and Cooper, A. F. and Ippolito, D. and Choquette-Choo, C. A. and Wallace, E. and Tramèr, F. and Lee, K. *Scalable Extraction of Training Data from (Production) Language Models*. arXiv preprint arXiv:2311.17035, 2023. https://arxiv.org/abs/2311.17035

[59] Shokri, R. and Stronati, M. and Song, C. and Shmatikov, V. *Membership Inference Attacks Against Machine Learning Models*. In *Proceedings of the 2017 IEEE Symposium on Security and Privacy*, pp. 3–18, 2017. https://doi.org/10.1109/SP.2017.41

[60] Carlini, N. and Nasr, M. and Choquette-Choo, C. A. and Jagielski, M. and Gleave, A. and Tramèr, F. and Wallace, E. *Are aligned neural networks adversarially aligned?*. arXiv preprint arXiv:2306.15447, 2023. https://arxiv.org/abs/2306.15447

[61] Tramer, F. and Zhang, F. and Juels, A. and Reiter, M. K. and Ristenpart, T. *Stealing Machine Learning Models via Prediction APIs*. In *Proceedings of the 25th USENIX Security Symposium*, pp. 601–618, 2016. https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/tramer

[62] Biggio, B. and Roli, F. *Wild Patterns: Ten Years After the Rise of Adversarial Machine Learning*. Pattern Recognition, 84:317–331, 2018. https://doi.org/10.1016/j.patcog.2018.07.006

[63] Jagielski, M. and Uesato, J. and Tramèr, F. and Li, B. and Roberts, A. and Celik, F. E. and Oprea, A. *High Accuracy and High Fidelity Extraction of Neural Networks*. In *Proceedings of the 29th USENIX Security Symposium*, pp. 1345–1362, 2020. https://www.usenix.org/conference/usenixsecurity20/presentation/jagielski

[64] ISO/IEC. *ISO/IEC 27001:2022 — Information Security Management Systems*. International Organization for Standardization, 2022. https://www.iso.org/standard/27001

[65] Lewis, P. and Perez, E. and Piktus, A. and Petroni, F. and Karpukhin, V. and Goyal, N. and Küttler, H. and Lewis, M. and Yih, W. T. and Rocktäschel, T. and others. *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks*. In *Advances in Neural Information Processing Systems 33*, pp. 9459–9474, 2020. https://proceedings.neurips.cc/paper/2020/hash/6b493230205778 31da812e9215cbfeba-Abstract.html

[66] Gao, Y. and Xiong, Y. and Gao, X. and Jia, K. and Pan, J. and Bi, Y. and Dai, Y. and Sun, J. and Wang, M. and Wang, H. *Retrieval-Augmented Generation for Large Language Models: A Survey*. arXiv preprint arXiv:2312.10997, 2023. https://arxiv.org/abs/2312.10997

[67] Xu, H. and others. *Machine Unlearning: A Survey*. ACM Computing Surveys, 57(1):1–36, 2024. https://doi.org/10.1145/3673608

[68] Zeng, Y. and Lin, H. and Zhang, J. and Yang, D. and Jia, R. and Shi, W. *How Johnny Can Persuade LLMs to Jailbreak Them: Rethinking Persuasion to Challenge AI Safety by Humanizing LLMs*. arXiv preprint arXiv:2401.06373, 2024. https://arxiv.org/abs/2401.06373

[69] Schick, T. and Dwivedi-Yu, J. and Dessì, R. and Raileanu, R. and Lomeli, M. and Zettlemoyer, L. and Cancedda, N. and Scialom, T. *Toolformer: Language Models Can Teach Themselves to Use Tools*. arXiv preprint arXiv:2302.04761, 2023. https://arxiv.org/abs/2302.04761

[70] Qin, Y. and Liang, S. and Ye, Y. and Zhu, K. and Yan, L. and Lu, Y. and Lin, Y. and Tang, X. and Zhou, X. and others. *ToolLLM: Facilitating Large Language Models to Master 16000+ Real-world APIs*. arXiv preprint arXiv:2307.16789, 2023. https://arxiv.org/abs/2307.16789

[71] Qian, C. and Liu, W. and Liu, H. and Yang, N. and Du, Y. and Chen, W. and Fu, B. and Chen, D. and Li, B. and Yang, J. and others. *ChatDev: Communicative Agents for Software Development*. arXiv preprint arXiv:2307.07924, 2023. https://arxiv.org/abs/2307.07924

[72] ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. 2019. https://www.isaca.org/resources/cobit

[73] National Institute of Standards and Technology. *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*. NIST, NIST SP 800-218, 2022. https://doi.org/10.6028/NIST.SP.800-218

[74] Cybersecurity and Infrastructure Security Agency. *CISA Roadmap for Artificial Intelligence (2023-2024)*. 2023. https://www.cisa.gov/sites/default/files/2023-11/2023-2024-CISA-Roadmap-for-AI_508c.pdf

[75] Brereton, P. and Kitchenham, B. A. and Budgen, D. and Turner, M. and Khalil, M. *Lessons from applying the systematic literature review process within the software engineering domain*. Journal of Systems and Software, 80(4):571–583, 2007. https://doi.org/10.1016/j.jss.2006.07.009

[76] Okoli, C. *A guide to conducting a standalone systematic literature review*. Communications of the Association for Information Systems, 37:43, 2015. https://doi.org/10.17705/1cais.03743

[77] Booth, A. and Sutton, A. and Papaioannou, D. *Systematic Approaches to a Successful Literature Review*. SAGE Publications, 2016. https://uk.sagepub.com/en-gb/eur/systematic-approaches-to-a-successful-literature-review/book240461

[78] Gartner Inc.. *Top Strategic Technology Trends for 2024: AI Trust, Risk and Security Management (AI TRiSM)*. 2023. https://www.gartner.com/en/information-technology/insights/top-technology-trends

[79] Pearce, H. and Ahmad, B. and Tan, B. and Dolan-Gavitt, B. and Karri, R. *Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions*. In *2023 IEEE Symposium on Security and Privacy (S&P)*, pp. 2106–2122, 2023. https://doi.org/10.1109/SP46215.2023.10179420

[80] Weidinger, L. and Mellor, J. and Rauh, M. and Griffin, C. and Uesato, J. and Huang, P. S. and Cheng, M. and Glaese, M. and Balle, B. and Kasirzadeh, A. and Biles, C. and Brown, S. and Kenton, Z. and Hawkins, W. and Stepleton, T. and Birhane, A. and Hendricks, L. A. and Gabriel, I. *Taxonomy of Risks posed by Language Models*. In *Proceedings of the 2022 ACM Conference on Fairness, Accountability, and Transparency*, pp. 214–229, 2022. https://doi.org/10.1145/3531146.3533088

[81] Liu, Y. and Deng, G. and Li, Y. and Wang, K. and Zhang, T. *Prompt Injection Attacks and Defenses in LLM-Integrated Applications*. arXiv preprint arXiv:2310.06836, 2023. https://arxiv.org/abs/2310.06836

[82] Xi, Z. and Chen, W. and Guo, X. and He, W. and Ding, Y. and Hong, B. and Zhang, M. and Wang, J. and Yang, S. and Zhao, W. and others. *The Rise and Potential of Large Language Model Based Agents: A Survey*. arXiv preprint arXiv:2309.07864, 2023. https://arxiv.org/abs/2309.07864

[83] Wang, L. and Chen, S. and Li, B. *A Survey on Large Language Model based Autonomous Agents*. Frontiers of Computer Science, 18(6):186345, 2024. https://doi.org/10.1007/s11704-024-40231-1

[84] European Parliament and Council of the European Union. *Regulation (EU) 2024/1689 of the European Parliament and of the Council on Artificial Intelligence (AI Act)*. Official Journal of the European Union, 2024. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689

[85] Organisation for Economic Co-operation and Development. *Recommendation of the Council on Artificial Intelligence (OECD/LEGAL/0449, updated)*. 2024. https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449

[86] U.S. Securities and Exchange Commission. *SEC Final Rule on Conflicts of Interest Associated with Predictive Data Analytics and AI*. 2024. https://www.sec.gov/rules/final/2024/33-11265

[87] ISACA. *State of AI Governance in the Enterprise 2024*. 2024. https://www.isaca.org/resources/reports/state-of-ai-governance-in-the-enterprise-2024

[88] U.S. Department of Health and Human Services, Office for Civil Rights. *HIPAA Guidance on Artificial Intelligence*. 2024. https://www.hhs.gov/hipaa/for-professionals/special-topics/artificial-intelligence/index.html